RAPPORT DE STAGE

SUJET

Élaboration d'une Démarche Automatisée de PenTest sur les Applications Web

Organisme d'acceuil : DATA PROTECT & JOBINTCH

Réalisé par :

M.ABOUBAKER SANE

Encadré par :

M. Ayoub NAJIM

M.Ayoub HRAZEM

M. Zine elabidine Darhbar

M.Yassine Abbade

M.Ariel Ngolle

Année de Formation : 2024

بسم الله الرحمن الرحيم

“ ***Je dédie ce mémoire :***

À Dieu, Le Tout-Puissant, Le Clément, Le Glorieux, Le Juste et Le Gracieux, qui m’a accordé la santé, la force et le courage tout au long de ces années d’études.

À ma très chère mère et à mon très cher père, aucun hommage ne saurait être à la hauteur de l’amour et de l'affection qu’ils ne cessent de me prodiguer. Qu'ils trouvent dans ce travail le témoignage de mon amour profond et de ma reconnaissance éternelle. Que Dieu leur accorde santé et longue vie.

À Ayoub Najime, pour son soutien inconditionnel et ses précieux conseils tout au long de mes études.

À mes frères et sœurs, je vous suis infiniment reconnaissant pour vos efforts, votre encouragement et votre soutien constant dans la quête de ma réussite.

À tous mes anciens formateurs et consultants pour leur soutien précieux et leur disponibilité à répondre à mes sollicitations.

Enfin, à toutes les personnes qui, de près ou de loin, ont contribué à la réussite de ce travail.

Merci à vous tous. ”

- ABOUBAKER SANE

Remerciement

C’est avec une immense gratitude que je dédie ces lignes à tous ceux qui ont contribué, de près ou de loin, à la réalisation et au succès de ce travail.

Tout d’abord, je rends grâce à Dieu, qui nous a accordé la force, la persévérance et la sagesse nécessaires pour mener à bien cette aventure.
J’aimerais adresser mes sincères remerciements à tout le corps professoral et à l’administration de **JOBINTCH** pour la formation académique que j'ai reçue. Je tiens particulièrement à remercier le coordinateur de la filière **Cybersécurité : Pentester Junior**. Votre engagement pour cette formation a été d’une valeur inestimable.

Je tiens à exprimer ma profonde reconnaissance à **Monsieur Lahrazem Ayoub**, leader en **Offensive Security**, dont le soutien inestimable et les compétences en cybersécurité et pentesting ont été déterminants dans l’évolution de mes connaissances.

Je remercie chaleureusement **Monsieur Ayoub Najim**, mon encadrant chez DATAPROTECT, pour sa disponibilité, ses précieux conseils et son expertise, partagés avec bienveillance tout au long de ce projet.
Mes remerciements sincères vont également à **Monsieur Zine elabidine Darhbar**, **Monsieur Yassine Abbade**, **et Monsieur Ariel Ngolle** pour leur soutien et leurs apports tout au long de cette démarche.

Enfin,. Je remercie également les membres du jury pour leur temps et leur considération dans l’évaluation de mon travail. À eux, j'adresse mes plus profonds respects.

Dédicaces

Nous tenons à exprimer notre profonde reconnaissance à l'entreprise DataProtect pour nous avoir offert l'opportunité de réaliser ce projet de stage. Votre soutien et votre encadrement ont été essentiels à la réussite de ce travail. Nous avons pu développer de nouvelles compétences et approfondir nos connaissances grâce à l'environnement stimulant et aux ressources que vous avez mises à notre disposition.

Nous souhaitons également remercier l'équipe de JobIntch pour leur collaboration et leur appui tout au long de ce projet. Votre expertise et vos conseils avisés ont grandement contribué à la qualité et au succès de notre travail.

À notre famille, dont l'affection et le soutien indéfectible nous ont permis de rester motivés et concentrés. Ce travail est le fruit de leur encouragement et de leur amour.

Enfin, nous tenons à exprimer notre gratitude à nos camarades et à nos proches pour leur soutien moral et leurs encouragements constants. Grâce à vous, nous avons pu surmonter les défis et mener ce projet à bien.

Résumé

Le présent rapport a été élaboré dans le cadre du projet de fin d'études réalisé chez DataProtect pour JobIntch. Ce projet revêt une grande importance car il nous offre l'opportunité de mettre en pratique les connaissances et les compétences acquises tout au long de notre formation.

Le choix du sujet est en adéquation avec les dernières technologies avancées disponibles sur le marché informatique. En l'occurrence, l'élaboration d'une démarche automatisée de PenTest sur les applications web apporte une valeur ajoutée significative dans le domaine de la sécurité informatique.

Dans le but d'accroître l'efficacité et de réduire le temps nécessaire aux tests de sécurité, cette démarche automatisée permettra de détecter et d'analyser les vulnérabilités des applications web de manière systématique. Le système sera capable de simuler différentes attaques pour identifier les points faibles et proposer des solutions de remédiation. Ce projet se concentrera sur les modules d'analyse des vulnérabilités, d'exploitation des failles et de génération de rapports de sécurité.

Abstract

Ce rapport a été préparé dans le cadre du projet de dernière année mené chez DataProtect pour JobIntch. Ce projet revêt une importance considérable car il nous offre l'opportunité de mettre en pratique les connaissances et les compétences acquises tout au long de notre formation académique.

Le choix du sujet s'aligne sur les dernières technologies avancées disponibles sur le marché informatique. Plus précisément, le développement d'une approche automatisée de PenTesting pour les applications Web ajoute une valeur considérable dans le domaine de la cybersécurité.

Pour améliorer l'efficacité et réduire le temps nécessaire aux tests de sécurité, cette approche automatisée détectera et analysera systématiquement les vulnérabilités des applications Web. Le système simulera diverses attaques pour identifier les faiblesses et proposer des solutions correctives. Ce projet se concentrera sur l'analyse des vulnérabilités, l'exploitation des failles de sécurité et la génération de rapports de sécurité.

Au cours des dernières années, les cyberattaques ont connu une augmentation considérable dans le monde numérique, en raison de l'avancée et de la démocratisation des technologies. Selon IBM Security, en 2022, plus de 80 % des organisations ont été victimes d'au moins une violation de données. Cette situation risque de s'aggraver avec la croissance rapide des objets connectés (IoT). En effet, selon le rapport de Cisco, le marché de l'IoT atteindra 75 milliards d'appareils d'ici 2025. À mesure que ces chiffres explosent, la surface d'exposition au risque de cybersécurité augmente. Compte tenu du coût colossal engendré par ces cyberattaques, elles peuvent également nuire à la réputation d'une entreprise.

Pour se prémunir contre ces cyberattaques, les entreprises adoptent de plus en plus des stratégies de cybersécurité et optent pour une évaluation régulière de leur posture de sécurité. L'une de ces stratégies fait l'objet de notre projet de fin d'études. En effet, durant mes quatre mois de stage chez Dataprotect, il a été question de réaliser un scénario de test d'intrusion automatisé pour des applications web.

Dans un premier temps, nous allons essayer de comprendre l'architecture et la configuration des applications web ciblées, puis aborder les notions liées au pentesting en général. Ensuite, nous effectuerons un benchmark des frameworks et méthodologies tels que NIST SP 800-115, PTES, OWASP Testing Guide, et d'autres modèles de base pour réaliser des tests de pénétration. Enfin, nous présenterons la méthodologie que nous avons proposée pour optimiser au maximum le pentest des applications web.

L'objectif de notre projet est de mettre en place une démarche automatisée qui permet d'évaluer la sécurité des applications web, depuis la phase de reconnaissance jusqu'à la phase de rapport, sans oublier les volets administratifs, à savoir le cadrage et la documentation.

Mots clés : Applications Web, Test de pénétration, Méthodologie, Automatisation.

Élaboration d'une Démarche Automatisée de PenTest sur les Applications Web 1
Remerciement 4
Dédicaces.....5
Résumé 6
Abstract 7
Liste des sigles et acronymes 13
CHAPITRE I 15
Introduction Générale 15
INSTITUTION DE STAGE 16
Offensive Security..... 19
DevSecOps :..... 19
ICS Security :..... 20
Red Team : 20
Audit d'architecture :..... 20
Audit de configuration :..... 20
Tests d'intrusion : (voir chapitre 2) 20
Sécurité applicative : 20
Gouvernance, Risk and Compliance 21
Cyberdefense..... 22
Security Intelligence 22
MSSP..... 23
Organigramme de Dataprotect 24
L'organigramme de Dataprotect 24
Contexte général et Conduite de projet..... 24
Contexte général 24
Problématique:..... 25
Solution : 25
Objectifs du projet..... 25
Conclusion du chapitre :..... 26
Chapitre II 27
Littérature et Étude des Concepts du Projet..... 27

Introduction 27
Définition et Vue d'Ensemble du Web Applicatif 27
Définition d'une Application Web 27
Structure générale du web applicatif 28
Client (Front-End) 28
Serveur web 29
Protocoles de l'application web 29
Avantages de l'application web : 30
Accessibilité : 30
Mise à jour facile : 30
Coûts réduits : 30
Scalabilité : 30
Interactivité et expérience utilisateur : 30
Présentation des Enjeux de Sécurité des Applications Web 31
Introduction 31
Enjeux de Sécurité 31
Confidentialité des Données 31
Intégrité des Données 31
Disponibilité des Services 31
Demarage de pentest web 32
Décomposer la tâche : 32
Fixer des objectifs clairs : 32
Créer un planning : 32
Utiliser la technique Pomodoro : 32
Identifier et éliminer les distractions : 32
Chercher de la motivation externe : 33
Trouver un partenaire de responsabilité : 33
Rappelle-toi de ton but final : 33
Reference pentest web 34
OWASP (Open Web Application Security Project) 34
Livres et Guides 34
Communautés et Forums 34
- Reddit r/netsec: Une communauté pour discuter de la sécurité informatique, y compris les pentests. 34
Plateformes de Pratique 34
OWASP TOP 10 35

Test d'intrusion 37
Définition et Contexte général 37
Les différents types de test d'intrusion 37
Test de pénétration réseau 37
Les différentes approches de test d'intrusion 38
Benchmark des principaux frameworks et métho- dologies de Pentesting 40
Penetration Testing Execution Standard 40
Pre-engagement interactions : 40
Information Gathering : 40
Threat Modeling : 40
Vulnerability Analysis 41
Exploitation : 41
Post-Exploitation : 41
Reporting : 41
Cyber Kill Chain Framework 42
Structure du cyber kill chain framework 42
Reconnaissance : 42
Weaponization : 43
Delivery : 43
Exploitation : 43
Command and Control : 44
Actions on objectifs : 44
Benchmark Tools 45
Chapitre III 46
L'automatisation de Penteste sur la cible WebGoat 46
Introduction 46
Objectifs du Pentest 46
Méthodologie 47
Limites et Contexte du Test 47
Synthèse des Résultats 47
Pré-requis 48
Étapes d'Installation 48
2. S'inscrire en tant que Nouvel Utilisateur 49
Rapport de Pentest : Challenge "WebGoat - Without Password" 51
OPTION 1 : Applications Web Enumeration 52
Inspection des requêtes HTTP : 53

2. Interception de la requête de connexion : 54
2. Test initial avec Burp Suite : 55
Exploitation : 57
Résultat de l'attaque : 58
Impact : 59
Recommandation: 59
Recommandations pour Corriger l'Injection SQL 59
Conclusion 61

Table des figures

FIGURE 1:DES PROJETS DE DATAPROTECT SUR UNE QUARANTAINE DE PAYS 18
FIGURE 2:LES REALISATIONS DE DATAPROTECT DEPUIS SA CREATION 19
FIGURE 3:LE DIFFERENTES UNITES D'AFFAIRES DATAPROTECT 19
FIGURE 4:SERVICES DE L'OFFENSIVE SECURITY DE DATAPROTECT 21
FIGURE 5:SERVICES DE LA BU GRC DE DATAPROTECT 21
FIGURE 6:SERVICES DE LA BU CYBERDEFENSE DE DATAPROTECT 22
FIGURE 7:: SERVICES DE LA BU SECURITY INTELLIGENCE DE DATAPROTECT 23
FIGURE 8:SERVICES DE LA BU MSSP DE DATAPROTECT 23
FIGURE 9:L'ORGANIGRAMME DE DATAPROTECT 24
FIGURE 10:VUE D'ENSEMBLE DE L'ANNUAIRE WEB APPLICATIF 28
FIGURE 11:DIFFERENTES APPROCHES DE TEST D'INTRUSION ET LEUR SPECIFICITE. 39
FIGURE 12:LES 7 PHASES DE LA METHODOLOGIE PTES 42
FIGURE 13:LES ETAPES DE CYBER KILL CHAIN 44
FIGURE 14:TABLEAUX DE BENCHMARK 45
FIGURE 15:OWASP - WEBGOAT 46
FIGURE 16:DEPLOYER WEBGOAT VIA DOCKER 48
FIGURE 17:VERIFICATION DE L'ACCESSIBLE VIA WEBGOAT 49
FIGURE 18:S'INSCRIRE DANS WEBGOAT 50
FIGURE 19:OUTIL DE AUTOMATISEE DE PENTEST SUR LES APPLICATIONS WEB 51
FIGURE 20:ENUMERATION CHALLENGE "WITHOUT PASSWORD" 52
FIGURE 21:LOGIN A WEBGOAT ET VOIR LE CHALLENGE WITHOUT PASSWORD 53
FIGURE 22:LANCE PROXY DE BURP SUITE 54
FIGURE 23:LANCE PROXY DE BURP SUITE 55
FIGURE 24:TEST D'INJECTION SQL 56
FIGURE 25:EXPLOITEE INJECTION SQL 57
FIGURE 26:L'EXPLOITATION REUSSIE 58

Liste des sigles et acronymes

- **HTTP**: *HyperText Transfer Protocol*
- **HTTPS**: *HyperText Transfer Protocol Secure*
- **CSP**: *Content Security Policy*
- **CSRF**: *Cross-Site Request Forgery*
- **CVE**: *Common Vulnerabilities and Exposures*
- **DOM**: *Document Object Model*
- **DoS**: *Denial of Service*
- **FQDN**: *Fully Qualified Domain Name*
- **HSTS**: *HTTP Strict Transport Security*
- **IDOR**: *Insecure Direct Object Reference*
- **LFI**: *Local File Inclusion*
- **OWASP**: *Open Web Application Security Project*
- **RCE**: *Remote Code Execution*
- **SSTI**: *Server-Side Template Injection*
- **SQLi**: *SQL Injection*
- **SSRF**: *Server-Side Request Forgery*
- **XSS**: *Cross-Site Scripting*
- **WAF**: *Web Application Firewall*
- **JWT**: *JSON Web Token*
- **API**: *Application Programming Interface*
- **SLA**: *Service Level Agreement*
- **WSDL**: *Web Services Description Language*
- **XML**: *Extensible Markup Languag*

- **NIST**: *National Institute of Standards and Technology*
- **NMAP**: *Network Mapper*
- **SSL**: *Secure Sockets Layer*
- **SSH**: *Secure Shell*
- **FTP**: *File Transfer Protocol*
- **SMTP**: *Simple Mail Transfer Protocol*
- **PenTest :** *Penetration Test*
- **HPP**: *HTTP Parameter Pollution*
- **PST:** *Penetration Testing Standard*
- **WSDL:** *Web Services Description Language*
- **SOAP:** *Simple Object Access Protocol*
- **JSONP:** *JSON with Padding (used for cross-domain requests)*
- **BSQL:** *Blind SQL Injection*
- **WPS:** *Web Proxy Server*
- **OWTF:** *Offensive Web Testing Framework*
- **SAST**: *Static Application Security Testing*
- **DAST**: *Dynamic Application Security Testing*
- **MFA***: Multi-Factor Authentication*
- **Fuzzing:** *Automated testing technique that inputs random data to find vulnerabilities*
- **ACL**: *Access Control List*
- **DirBuste**r: *Directory and file brute-forcing tool*
- **Burp Suite:** *Web vulnerability scanner and penetration testing tool*
- **Zap:** *OWASP Zed Attack Proxy (web application security testing tool)*

CHAPITRE I

Introduction Générale

De nos jours, la connectivité numérique est omniprésente et en constante expansion, facilitant les échanges et la gestion des services à l'échelle mondiale. Cependant, cette transformation numérique s'accompagne d'une augmentation des cybermenaces, rendant les systèmes, réseaux et infrastructures en ligne plus vulnérables aux attaques malveillantes. Les conséquences économiques et sociales de ces attaques affectent non seulement les entreprises, mais aussi les administrations et les particuliers à travers le globe. Parmi les cybermenaces actuelles, on trouve les attaques par injection SQL, les ransomwares, le phishing, et les violations de données. Ces exemples ne représentent qu'une fraction des diverses cybermenaces qui continuent de croître en complexité et en fréquence.

Dans cet environnement numérique, les cybercriminels évoluent rapidement, devenant plus sophistiqués et organisés. Ils exploitent les failles technologiques, préparent des attaques ciblées et collaborent de manière stratégique pour compromettre les systèmes de sécurité. Les cyberattaques sont souvent transnationales, ce qui crée des défis supplémentaires pour les enquêtes et les poursuites judiciaires, car les victimes, les infrastructures et les criminels sont souvent situés dans différentes juridictions.

La sécurité des applications web est devenue une priorité pour les entreprises. Ces applications sont souvent des vecteurs d'attaque privilégiés par les cybercriminels, car elles sont accessibles en ligne et peuvent contenir des données sensibles. De plus, les erreurs humaines et les mauvaises configurations augmentent les risques d'exploitation des vulnérabilités des applications web, en faisant une cible de choix pour les cyberattaquants.

Dans ce contexte, Dataprotect, une entreprise leader dans la cybersécurité, s'efforce d'améliorer continuellement les services offerts à ses clients. Dans le cadre de notre stage de fin d'études au sein de l'unité Offensive Security de cette entreprise, nous avons entrepris de développer une méthodologie permettant d'automatiser le test de pénétration des applications web. La problématique à laquelle nous répondons est la suivante : comment pouvons-nous améliorer et automatiser les tests de sécurité des applications web pour renforcer leur protection contre les cybermenaces ?

INSTITUTION DE STAGE

Dans ce chapitre nous mettons l'accent sur la présentation del'entreprise d'accueil pour notre projet de stage. Nous présenterons l'histoire de l'entreprise, ces diffé- rents services,son organisation ainsi quelques les chiffres clés illustrant sa présence sur le marché. Ensuite, nous présenterons le contexte général, la problématique et les objectifs du projet. Enfin nous compléterons cette partie avec la démarche suivie pour la gestion et le management de ce projet.

Présentation de l'entreprise

DATAPROTECT est une entreprise marocaine spécialisée dans la sécurité de l'information, fondée en 2009 par Ali EL AZZOUZI, un expert renommé dans le domaine. Avec une expérience riche en projets de conseil et d'intégration de solutions de sécurité, aussi bien au Maroc qu'à l'international, DATAPROTECT a su se positionner comme un acteur clé dans le secteur. La société se distingue par sa vision unifiée de la sécurité de l'information, en offrant des services adaptés aux besoins de ses clients tout en maintenant une expertise unique sur le marché local et régional.

Depuis sa création, DATAPROTECT a connu une croissance continue et se distingue par la qualité de ses prestations, portées par une équipe multidisciplinaire d'experts en cybersécurité. L'entreprise est particulièrement reconnue pour son statut de première entité accréditée PCI QSA au Maroc par le Payment Card Industry Security Standards Council (PCI SSC), lui permettant de certifier la conformité des entreprises avec les normes PCI DSS (Payment Card Industry Data Security Standard) et PA DSS (Payment Application Data Security Standard). Ce statut renforce son leadership en Afrique du Nord, en Afrique subsaharienne, ainsi qu'au Moyen-Orient.

Selon les statistiques de 2024, DATAPROTECT peut s'appuyer sur un large portefeuille de clients internationaux, incluant des multinationales et des

entreprises locales, ce qui témoigne de sa capacité à délivrer des services de sécurité à la fois agiles et personnalisés.

Quelques chiffres clés de l'organisation aujourd'hui :

+200 employés, dont 120 consultants spécialisés en sécurité informatique ;

+250 certifications de sécurité détenues par les employés, garantissant un niveau de compétence élevé ;

+400 clients actifs, répartis à travers différentes industries et secteurs ;

+2000 projets menés avec succès dans plus de 50 pays ;

20 millions d'euros de chiffre d'affaires, avec 85% de revenus générés à l'international ;

Une filiale en France créée en 2016 ;

Une filiale AWARINO dédiée à la sensibilisation et à la formation en cybersécurité, établie en 2019 ;

Une nouvelle filiale en Côte d'Ivoire, lancée en 2022 pour renforcer sa présence en Afrique de l'Ouest ;

Une filiale à Dubaï ouverte en 2023 pour répondre à la demande croissante de services de cybersécurité au Moyen-Orient.

DATAPROTECT s'investit également dans le développement de solutions innovantes en cybersécurité, via une équipe dédiée à la recherche et développement. Cette équipe travaille sur des projets novateurs pour anticiper et répondre aux nouvelles menaces de l'écosystème numérique. L'entreprise a mis en place des solutions pour divers secteurs, allant des services financiers aux infrastructures critiques, en passant par la santé et les télécommunications.

Un des grands projets récents de DATAPROTECT est la création d'une plateforme de simulation d'attaques qui permet à ses clients de tester leur résilience face à différentes cybermenaces. Ce projet s'inscrit dans une

stratégie globale de renforcement de la sécurité proactive et de la gestion des risques pour les entreprises.

Avec son réseau mondial en pleine expansion, ses certifications prestigieuses et ses projets innovants, DATAPROTECT continue de se positionner comme un leader régional et un acteur global en matière de sécurité de l'information et de cybersécurité.

Figure 1:Des projets de dataprotect sur une quarantaine de pays

Au fil des ans, l'entreprise s'est distinguée par l'acquisition de plusieurs certifications internationales. Animée par sa volonté d'offrir un service de qualité de proximité, Dataprotect a connu une évolution significative et a élargi sa présence ainsi que sa renommée dans le domaine de la cybersécurité.

Figure 2:Les réalisations de Dataprotect depuis sa création

Dataprotect : une vision 360 ° de la cybersécurité

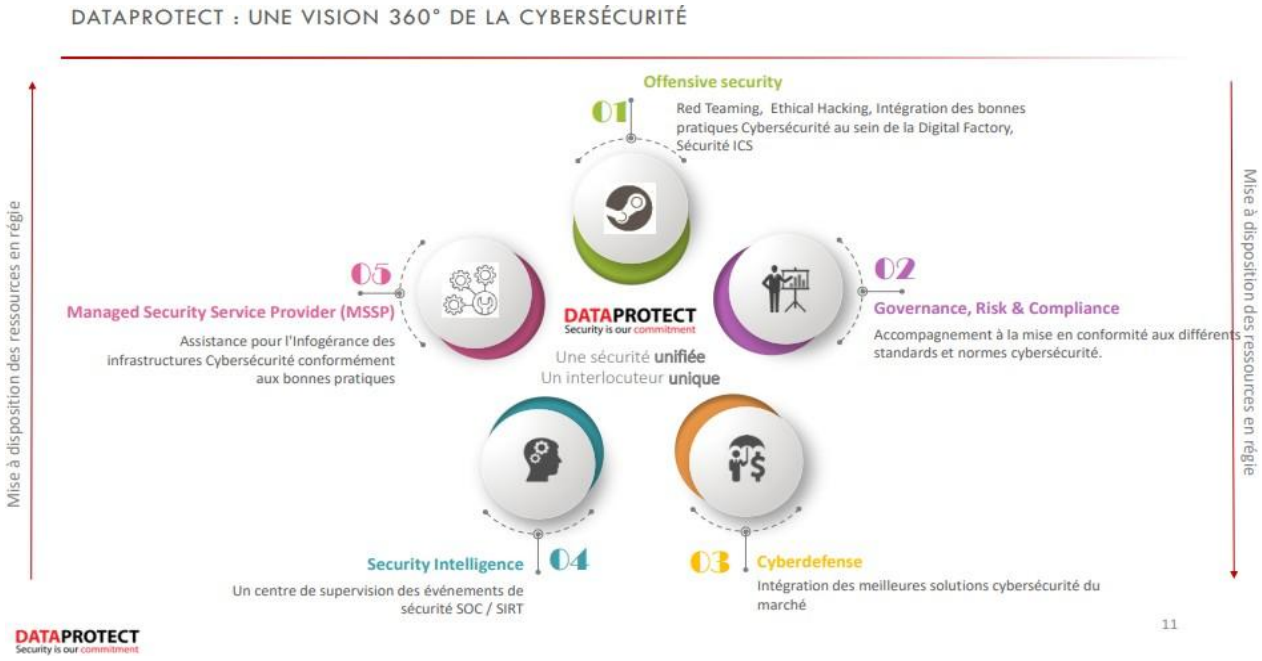

Figure 3:Le différentes unités d'affaires Dataprotect

Offensive Security

La Business Unit (BU) Offensive Security de Dataprotect propose une gamme diversifiée de services visant à renforcer la sécurité des systèmes et des applications de ses clients. Parmi ces services, on trouve :

DevSecOps :

Cette méthodologie vise à intégrer la sécurité dès les phases de développement et de déploiement des logiciels. En combinant développement, sécurité et opérations, le DevSecOps permet de prévenir et d'atténuer les failles potentielles en adoptant des pratiques de sécurité proactives tout au long du cycle de vie du développement logiciel.

ICS Security :

Ce service se concentre sur la sécurisation des systèmes de contrôle industriels (ICS), essentiels pour le fonctionnement des infrastructures critiques. Dataprotect accompagne ses clients dans la mise en œuvre de mesures de sécurité adaptées pour protéger ces systèmes contre les cybermenaces, en s'assurant de leur conformité aux normes et réglementations spécifiques au secteur.

Red Team :

Ce service consiste à effectuer des simulations d'attaques en conditions réelles afin d'évaluer les faiblesses des systèmes d'information et de tester l'efficacité des mesures de défense en place. Les équipes Red Team emploient des techniques variées pour reproduire des scénarios d'attaques, permettant ainsi aux clients de renforcer leur posture de sécurité.

Audit d'architecture :

L'audit d'architecture est une évaluation approfondie de l'infrastructure informatique d'une organisation. Ce processus examine l'architecture des réseaux, des systèmes et des applications pour identifier les vulnérabilités et recommander des améliorations qui renforcent la sécurité globale.

Audit de configuration :

Ce service se concentre sur l'évaluation des configurations spécifiques des systèmes, des réseaux et des applications. L'objectif est de vérifier que les configurations sont optimales, sécurisées et conformes aux normes de l'industrie. Un audit de configuration peut contribuer à réduire les risques liés aux erreurs de configuration qui pourraient être exploitées par des attaquants.

Tests d'intrusion : (voir chapitre 2)

Sécurité applicative :

La sécurité applicative se réfère à la protection des applications contre les menaces et les activités malveillantes. Dataprotect met en œuvre des stratégies

de sécurisation pour garantir que les applications développées et déployées sont résilientes face aux cyberattaques. Cela inclut l'évaluation de la sécurité dès la conception, ainsi que l'application de tests réguliers pour détecter les vulnérabilités.

Figure 4:Services de l'offensive security de Dataprotect

Gouvernance, Risk and Compliance

Le métier de cybersécurité est un domaine essentiel qui vise à protéger les systèmes d'information, les réseaux et les données des entreprises contre les menaces numériques. Les professionnels de la cybersécurité sont responsables de l'identification des vulnérabilités potentielles, de la mise en place de mesures de protection, et de la réponse aux incidents de sécurité. La Business Unit (BU) Cybersécurité de Dataprotect propose les services suivants à ses clients

Figure 5:Services de la BU GRC de dataprotect

Cyberdefense

La cyberdéfense est un ensemble de mesures visant à protéger les systèmes informa- tiques, les réseaux, les données et les informations contre les menaces et les attaques malveillantes. Elle consiste à mettre en place des solutions de sécurité informatique pour identifier, prévenir, détecter et répondre aux cyberattaques. Les activités de de la BU CyberDefense s'articulent autour des activités suivantes :

Figure 6:Services de la BU cyberdefense de dataprotect

Security Intelligence

La **Security Intelligence** désigne la pratique consistant à collecter, normaliser et analyser en temps réel les données générées par les réseaux, applications et autres infrastructures informatiques. Ces informations sont ensuite utilisées pour évaluer et renforcer la posture de sécurité d'une organisation. Cette discipline combine l'utilisation de ressources logicielles et humaines dans le but d'identifier des informations exploitables permettant de prévenir les menaces et de réduire les risques auxquels l'organisation est exposée. En résumé, l'intelligence de sécurité consiste à exploiter les données afin de prendre des décisions éclairées pour améliorer la sécurité organisationnelle.

Figure 7:: Services de la BU Security Intelligence de dataprotect

MSSP

La BU MSSP (Managed Security Service Provider) regroupe une équipe d'experts spécialisés dans la protection des entreprises contre les menaces de sécurité. Leur mission consiste à fournir des solutions logicielles ainsi que des services visant à sécuriser les données de l'entreprise, tout en offrant un soutien constant par le biais d'un réseau d'experts en cybersécurité. Ces spécialistes sont prêts à intervenir immédiatement pour répondre aux attaques dès qu'elles surviennent.

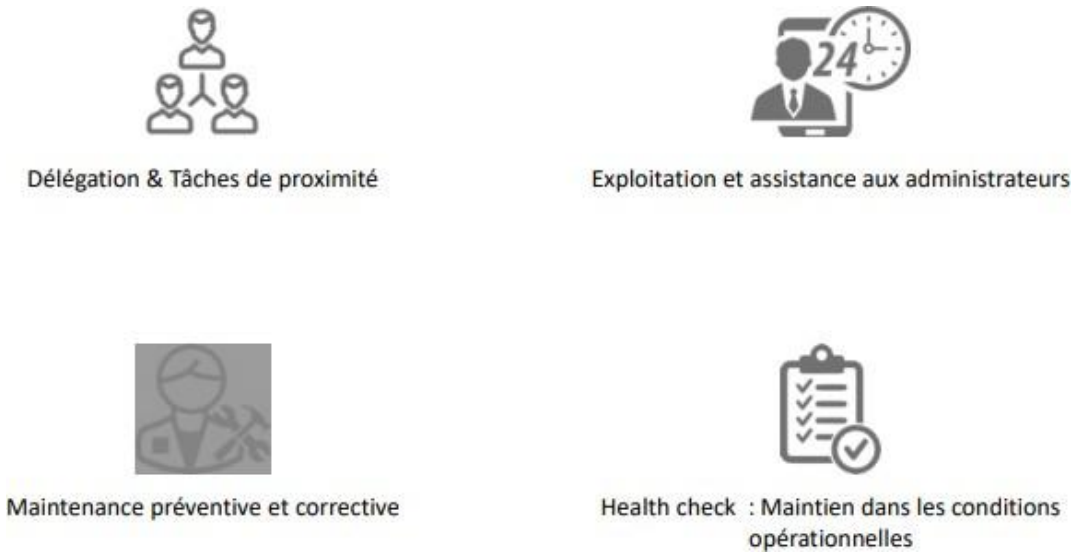

Figure 8:Services de la BU MSSP de dataprotect

Organigramme de Dataprotect

L'Organigramme de Dataprotect est structure sous forme hiérarchique avec entête le CEO Monsieur Ali EL AZZOUZI.Il peut-être présenté comme suit

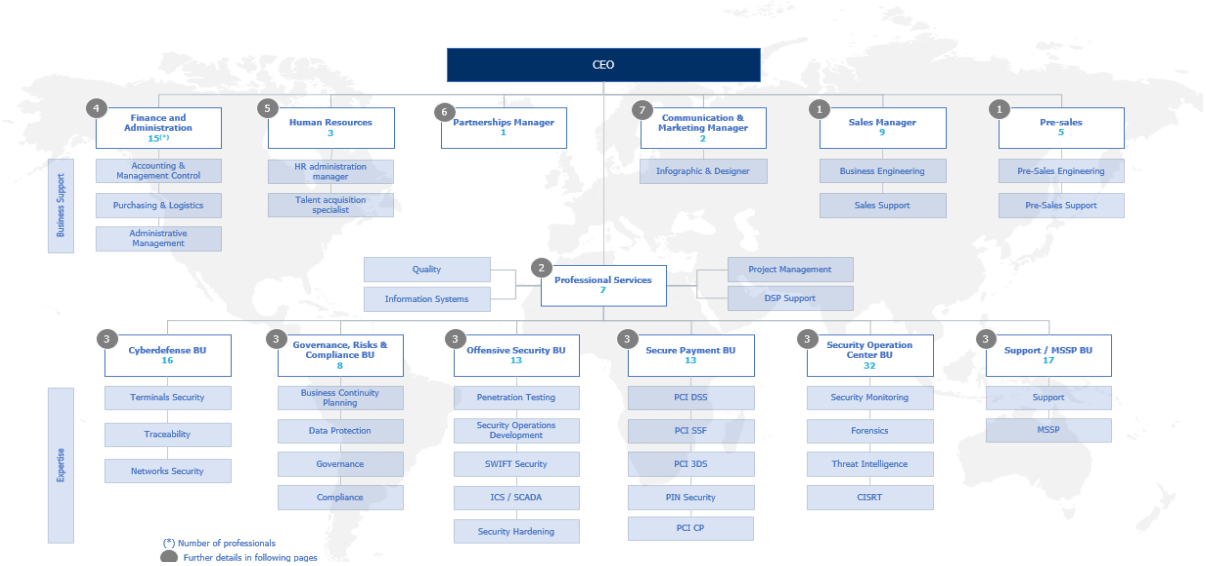

Figure 9:l'organigramme de Dataprotect

L'organigramme de Dataprotect

Contexte général et Conduite de projet

Contexte général

La sécurité des applications web constitue une préoccupation majeure pour les entreprises, car elles renferment des informations sensibles telles que les identifiants des utilisateurs, les données personnelles et les ressources critiques. Toutefois, la complexité des infrastructures web et la quantité importante de données qu'elles traitent peuvent rendre difficile la détection des failles de sécurité, posant ainsi un véritable défi pour les équipes de sécurité informatique.

Pour mettre en place des mesures de sécurité adéquates et prévenir l'exploitation de ces failles par des cybercriminels, les pentesters recourent à des outils automatisés et manuels. Ces outils permettent d'identifier les vulnérabilités, les erreurs de configuration, les injections SQL, les failles XSS, ainsi que les mots de passe faibles. L'implémentation d'une démarche de pentesting automatisée

facilite la détection rapide et efficace des vulnérabilités potentielles, permettant ainsi aux pentesters de repérer rapidement les points faibles des applications web et de mettre en œuvre des mesures correctives pour renforcer la sécurité de l'entreprise.

Problématique:

Avec la croissance rapide des applications web et leur adoption massive par les entreprises, les cyberattaques deviennent de plus en plus fréquentes et sophistiquées. Assurer la sécurité de ces applications est désormais une priorité absolue pour prévenir la fuite de données sensibles et garantir la continuité des services. Toutefois, les tests de pénétration manuels peuvent s'avérer chronophages, coûteux, et sujets à l'erreur humaine. En conséquence, une approche plus systématique et automatisée devient nécessaire pour identifier efficacement les vulnérabilités des applications web, réduire les délais d'analyse, et garantir une évaluation continue de la sécurité. Comment concevoir une démarche automatisée de pentest capable de couvrir l'ensemble des surfaces d'attaque des applications web tout en s'intégrant dans les processus de développement modernes comme?

Solution :

La solution à la problématique consiste à développer une méthodologie automatisée de test de pénétration pour les applications web, utilisant des langages de scripting comme Python et PowerShell. Cette méthodologie permet d'automatiser les étapes clés du pentesting, telles que l'énumération, la détection de vulnérabilités, et l'exploitation des failles, en s'appuyant sur des outils comme OWASP ZAP ou Burp Suite. Les scripts créés orchestreront les tests de sécurité de manière fluide et sans intervention humaine, facilitant ainsi l'identification rapide des failles de configuration et des vulnérabilités. En intégrant ces scripts dans des workflows automatisés, la solution permet d'effectuer des tests continus tout au long du cycle de vie des applications, assurant une sécurité renforcée et une réponse proactive aux menaces émergentes.

Objectifs du projet

L'objectif principal de ce projet est de concevoir une démarche automatisée permettant d'automatiser le test de pénétration des applications web. La méthode inclut les processus que les attaquants peuvent utiliser pour compromettre la sécurité des applications. Pour atteindre cet objectif, nous nous fixons les objectifs suivants :

✓ **Comprendre l'architecture et le fonctionnement des applications web**, ainsi que les techniques de test de pénétration (Pentest), afin de concevoir une démarche efficace pour l'automatisation.

✓ **Concevoir une méthodologie de test de pénétration automatisée** qui couvre les principales vulnérabilités et techniques de compromission des applications web. Cette méthodologie devra être rigoureuse, fiable et flexible.

✓ **Tester et valider la démarche de Pentest** en utilisant des scénarios de test sur des environnements virtuels pour garantir son efficacité et sa fiabilité.

✓ **Mettre à jour régulièrement la démarche** pour inclure les nouvelles vulnérabilités et les techniques de test de pénétration émergentes. Cette veille technologique permettra d'assurer la pertinence de la méthodologie élaborée ainsi que son efficacité à long terme.

Conclusion du chapitre :

Ce chapitre a permis de présenter DATAPROTECT, l'entreprise d'accueil de notre projet de stage. Fortement implantée dans le domaine de la cybersécurité depuis 2009, cette société marocaine se distingue par son expertise, ses services variés et sa capacité à anticiper les menaces. Grâce à une stratégie basée sur l'innovation, DATAPROTECT s'est imposée comme un leader régional et global dans la sécurité de l'information. Ce contexte a fourni un cadre solide pour la mise en place de notre projet, répondant ainsi à la problématique de l'automatisation des tests de pénétration pour les applications web. L'objectif est de créer une démarche efficace et évolutive, permettant une évaluation continue des vulnérabilités tout en s'intégrant aux processus de développement modernes.

Chapitre II

Littérature et Étude des Concepts du Projet

Introduction

Ce chapitre couvre les concepts fondamentaux et les termes liés à l'automatisation des tests de pénétration (pentesting) des applications web. Nous explorerons les définitions clés, discuterons des méthodologies et frameworks utilisés dans les tests de pénétration, ainsi que l'importance des outils d'automatisation pour les applications web. De plus, nous passerons en revue les protocoles de sécurité web, les langages de scripting comme Python et Bash, et leur rôle crucial dans l'élaboration de scripts de pentesting automatisés.

Définition et Vue d'Ensemble du Web Applicatif

Définition d'une Application Web

Une **application web** est un programme logiciel qui s'exécute sur un serveur web et auquel les utilisateurs accèdent via un navigateur internet. Contrairement aux applications de bureau, qui nécessitent une installation sur chaque machine locale, les applications web sont accessibles à distance sur n'importe quel appareil disposant d'une connexion internet et d'un navigateur compatible.

Les applications web utilisent généralement une architecture **client-serveur**, où le navigateur de l'utilisateur (le **client**) envoie des requêtes au serveur via le protocole HTTP ou HTTPS. Le serveur traite ensuite ces requêtes et renvoie les réponses sous forme de pages HTML, qui sont rendues dans le navigateur pour que l'utilisateur puisse interagir avec l'application.

Les applications web peuvent avoir une grande variété de fonctionnalités, allant de simples formulaires en ligne à des systèmes complexes comme des plateformes de gestion de contenu (CMS), des services bancaires en ligne, ou des applications SaaS (Software as a Service).

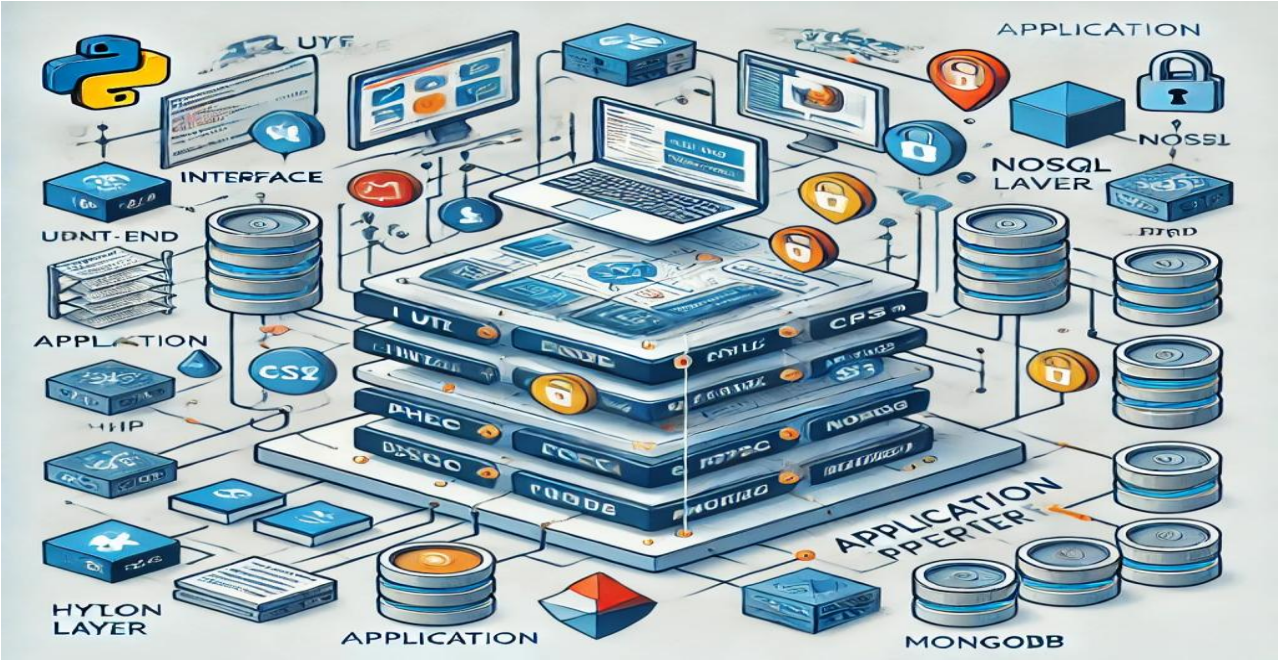

Figure 10:Vue d'ensemble de l'annuaire web applicatif

Structure générale du web applicatif

La structure générale d'une application web repose sur plusieurs composantes essentielles qui interagissent pour permettre le bon fonctionnement de l'application. Voici un aperçu de ces composantes :

Client (Front-End)

Le client, souvent appelé **front-end**, est la partie visible de l'application web avec laquelle les utilisateurs interagissent directement via leur navigateur. Il est constitué de plusieurs technologies :

- **HTML (HyperText Markup Language)** : Structure la page web en définissant les éléments de base comme les titres, paragraphes, images, formulaires, etc.
- **CSS (Cascading Style Sheets)** : Utilisé pour styliser et rendre la page plus attractive en définissant les couleurs, polices, dispositions, etc.

- **JavaScript** : Langage de programmation qui permet d'ajouter des fonctionnalités dynamiques et interactives, comme les formulaires, les animations ou les actions côté client.

Serveur web

Le **serveur web** est la partie responsable de la réception des requêtes des utilisateurs (clients) et de l'envoi des réponses appropriées. Ce serveur héberge l'application et est responsable du traitement des requêtes HTTP/HTTPS venant des navigateurs. Il peut également être responsable de la gestion des accès, de la sécurité, et de la distribution des ressources.

Exemples de serveurs web : **Apache**, **Nginx**, **IIS**.

Protocoles de l' application web

Les protocoles de communication jouent un rôle crucial dans le fonctionnement des applications web. Le protocole HTTP (Hypertext Transfer Protocol) est le fondement de l'échange d'informations sur le Web, permettant aux clients (navigateur) et aux serveurs d'interagir. HTTPS (HTTP Secure) ajoute une couche de sécurité en chiffrant les données échangées, garantissant ainsi la confidentialité et l'intégrité des informations. D'autres protocoles comme WebSocket facilitent une communication bidirectionnelle en temps réel entre le client et le serveur, essentielle pour des applications interactives. En outre, des protocoles comme REST (Representational State Transfer) et GraphQL sont utilisés pour structurer les API, permettant une intégration efficace des services et des données. Ces protocoles sont essentiels pour assurer une expérience utilisateur fluide et sécurisée lors de l'utilisation d'applications web.

Avantages de l’application web :

Les applications web offrent plusieurs avantages significatifs par rapport aux applications de bureau traditionnelles, ce qui en fait un choix privilégié pour de nombreuses entreprises et utilisateurs. Voici quelques-uns des principaux avantages :

Accessibilité :

Les applications web sont accessibles depuis n'importe quel appareil connecté à Internet, que ce soit un ordinateur, une tablette ou un smartphone. Cela permet aux utilisateurs de se connecter et d'utiliser l'application de n'importe où, sans nécessiter d'installation spécifique.

Mise à jour facile :

Les mises à jour des applications web se font généralement sur le serveur, ce qui signifie que tous les utilisateurs bénéficient instantanément des nouvelles fonctionnalités et corrections de bogues sans avoir besoin de télécharger ou d'installer quoi que ce soit.

Coûts réduits :

Étant donné que les applications web ne nécessitent pas d'installation locale, cela réduit les coûts de maintenance et de déploiement. De plus, les utilisateurs peuvent souvent accéder à des applications basées sur un modèle d'abonnement, ce qui peut être plus économique.

Scalabilité :

Les applications web peuvent être facilement mises à l'échelle pour gérer une augmentation du nombre d'utilisateurs ou des demandes de service. Les ressources serveur peuvent être ajustées en fonction des besoins, offrant une flexibilité accrue.

Interactivité et expérience utilisateur :

Les technologies modernes telles que AJAX, HTML5 et CSS3 permettent de créer des interfaces utilisateur interactives et réactives. Cela améliore l'expérience utilisateur en rendant les applications plus intuitives et engageantes..5 Avantages de l’application web

Présentation des Enjeux de Sécurité des Applications Web

Introduction

Les applications web jouent un rôle crucial dans la vie quotidienne des entreprises et des particuliers. Elles facilitent une multitude de tâches, allant des transactions financières aux communications personnelles, en passant par la gestion de données sensibles. Cependant, cette dépendance accrue aux applications web s'accompagne d'une augmentation des risques de sécurité. Les cyberattaques visant les applications web sont de plus en plus sophistiquées, mettant en péril la confidentialité, l'intégrité et la disponibilité des données

Enjeux de Sécurité

Confidentialité des Données

- Les applications web traitent souvent des informations sensibles, telles que des données personnelles, financières et professionnelles. La protection de ces données contre les accès non autorisés est essentielle pour prévenir le vol d'identité, la fraude et d'autres activités malveillantes.

Intégrité des Données

L'intégrité des données garantit que les informations stockées et transmises restent exactes et complètes. Toute altération non autorisée peut entraîner des conséquences graves, telles que des erreurs dans les transactions financières, des perturbations des opérations et la perte de confiance des utilisateurs.

Disponibilité des Services

La disponibilité des applications web est cruciale pour assurer un service continu et fiable. Les attaques par déni de service (DoS) et les ransomwares peuvent rendre les applications inaccessibles, entraînant des interruptions de service, des pertes financières et une détérioration de la réputation de l'entreprise.

Demarage de pentest web

Pour commencer un pentest web,Voici quelques suggestions pour surmonter cette procrastination :

Décomposer la tâche :

Divise le processus de démarrage des tests de pénétration en petites étapes réalisables. Cela peut inclure la recherche d'informations, la configuration des outils, et la préparation de l'environnement de test. Commencer par des petites tâches peut rendre le processus moins intimidant.

Fixer des objectifs clairs :

Établis des objectifs spécifiques et mesurables pour chaque session de travail. Par exemple, "Aujourd'hui, je vais configurer et tester l'outil X sur l'application Y". Cela te donne une direction claire et un sentiment d'accomplissement une fois l'objectif atteint.

Créer un planning :

Alloue des plages horaires dédiées à cette activité dans ton emploi du temps. Traite-les comme des rendez-vous importants que tu ne peux pas manquer. Cela aide à structurer ton temps et à éviter les distractions.

Utiliser la technique Pomodoro :

Alterne entre des périodes de travail concentré (25 minutes) et des pauses courtes (5 minutes). Cela peut améliorer ta concentration et réduire la fatigue mentale.

Identifier et éliminer les distractions :

Réduis les interruptions possibles en travaillant dans un environnement propice à la concentration. Cela peut inclure la désactivation des notifications ou l'utilisation d'applications qui bloquent les sites distrayants.

Chercher de la motivation externe :

Lis des articles ou des études de cas sur des pentests réussis pour te motiver. Comprendre l'impact positif de ton travail peut t'encourager à démarrer.

Trouver un partenaire de responsabilité :

Partage tes objectifs et tes progrès avec un collègue ou un ami qui peut te soutenir et te motiver à respecter tes engagements.

Rappelle-toi de ton but final :

Garde en tête l'importance de ton projet de fin d'études et comment cela peut affecter tes perspectives professionnelles futures. Cela peut te motiver à surmonter la procrastination

Reference pentest web

Pour commencer un pentest web, il est utile de se référer à des ressources fiables qui couvrent les méthodologies, les outils et les techniques. Voici quelques références essentielles pour t'aider dans ton projet de pentest web :

OWASP (Open Web Application Security Project)

- OWASP Top Ten: Ce document répertorie les dix principales vulnérabilités des applications web. Il est une référence incontournable pour comprendre les risques de sécurité courants.

- OWASP Testing Guide: Ce guide détaillé fournit une méthodologie complète pour effectuer des tests de sécurité sur les applications web.

Livres et Guides

- "**The Web Application Hacker's Handbook**" par Dafydd Stuttard et Marcus Pinto : Ce livre est une excellente ressource pour les tests de pénétration d'applications web, couvrant une variété de techniques et d'outils.

- **"Hacking: The Art of Exploitation"** par Jon Erickson : Bien que plus général, ce livre offre une solide compréhension des concepts de sécurité informatique.

Communautés et Forums

- Reddit r/netsec: Une communauté pour discuter de la sécurité informatique, y compris les pentests.

- Security Stack Exchange: Une plateforme de questions-réponses pour les professionnels de la sécurité informatique.

Plateformes de Pratique

- **Hack The Box**: Une plateforme pour pratiquer le pentesting avec des machines virtuelles conçues pour être piratées.

- **TryHackMe:** Un site interactif pour apprendre la cybersécurité et le pentesting.

OWASP TOP 10

L'OWASP Top Ten est une liste des dix principales vulnérabilités de sécurité des applications web, régulièrement mise à jour par l'Open Web Application Security Project (OWASP). Cette liste est une référence essentielle pour les développeurs et les professionnels de la sécurité, car elle aide à identifier et à se protéger contre les menaces les plus courantes. Voici les dix vulnérabilités du dernier OWASP Top Ten (2021) :

1. A01:2021 - Broken Access Control

Les contrôles d'accès défaillants permettent aux utilisateurs de contourner les restrictions et d'accéder à des fonctionnalités ou des données auxquelles ils ne devraient pas avoir accès. Cela peut inclure la modification de l'URL, la manipulation de tokens, ou l'élévation de privilèges.

2. ***A02:2021 - Cryptographic Failures***

Les échecs cryptographiques se produisent lorsque des données sensibles ne sont pas correctement protégées, qu'il s'agisse de données en transit ou stockées. Cela peut inclure l'utilisation de protocoles de chiffrement faibles, le manque de chiffrement des données sensibles, ou une mauvaise gestion des clés.

3. ***A03:2021 - Injection***

L'injection se produit lorsque des données non fiables sont envoyées à un interpréteur dans le cadre d'une commande ou d'une requête. Les attaques les plus courantes incluent l'injection SQL, l'injection de commande OS, et l'injection LDAP.

4. A04:2021 - Insecure Design

Le design non sécurisé fait référence à des erreurs de conception qui entraînent des failles de sécurité. Cela inclut l'absence de contrôles de sécurité intégrés, le manque de validation des données, et des flux de travail non sécurisés.

5. A05:2021 - Security Misconfiguration

Les mauvaises configurations de sécurité sont des erreurs qui se produisent lorsque les paramètres de sécurité ne sont pas correctement définis ou sont laissés à leurs valeurs par défaut. Cela inclut les configurations incorrectes des serveurs, des bases de données, et des frameworks.

6. A06:2021 - Vulnerable and Outdated Components

L'utilisation de composants vulnérables ou obsolètes expose les applications aux failles connues. Cela inclut les bibliothèques, les frameworks, et les plugins qui ne sont pas à jour ou contiennent des vulnérabilités non corrigées

.

7. A07:2021 - Identification and Authentication Failures

Les échecs d'identification et d'authentification se produisent lorsque les mécanismes de gestion des identifiants sont compromis. Cela inclut les mots de passe faibles, le manque de protection contre les attaques par force brute, et la gestion inefficace des sessions.

8. A08:2021 - Software and Data Integrity Failures

Les défaillances d'intégrité logicielle et des données se produisent lorsque des logiciels ou des données sont compromis par des attaques comme l'altération de mise à jour ou la falsification de données, en particulier pour les logiciels ou les scripts auto-hébergés.

A09:2021 - Security Logging and Monitoring Failures

Les échecs de journalisation et de surveillance de sécurité se produisent lorsqu'il n'y a pas de suivi adéquat des événements de sécurité, ce qui empêche la détection des incidents et des réponses appropriées.

10. A10:2021 - Server-Side Request Forgery (SSRF)

L'attaque SSRF se produit lorsque l'application web récupère une ressource distante sans valider l'URL fournie par l'utilisateur. Cela permet à l'attaquant de forger des requêtes vers d'autres services internes.

Test d’intrusion

Définition et Contexte général

Un test d'intrusion, ou pentest, est un processus de sécurité informatique visant à simuler des attaques réelles sur des systèmes ou des applications afin d'identifier et d'exploiter des vulnérabilités potentielles. Contrairement à une simple analyse de vulnérabilités, le pentest inclut des étapes d'exploitation manuelle ou automatisée des failles détectées, permettant ainsi de mesurer l'impact réel des failles sur la sécurité d'une organisation. L'objectif est d'évaluer la robustesse des mesures de défense en place et de fournir des recommandations pour renforcer la sécurité contre des cyberattaques potentielles.

Les différents types de test d’ intrusion

Il existe plusieurs types de test de pénétration,chacun avec ses objectifs et ses spécifi- cités. parmi les plus fréquents on peut en citer :

Test de pénétration réseau

Ce type de test consiste à identifier les possibles vulnérabilités réseau d’une entreprise telles que les ports ouverts ,les services et les failles de configuration etc… .Ce type de pentest peut être découpée en deux sous-catégories à savoir :

a) **Test de pénétration interne** Le test d’intrusion interne est éffectué à partir du réseau interne de l’entreprise. Le pentester a donc accés directement au réseau de l’entreprise.
b) **Test de pénétration externe** Le test d’intrusion externe est éffectué quant à lui à l’extérieur de l’entreprise. L’auditeur va ainsi faire son test à partir des services disponibles sur internet.

Test de pénétration applicatif

Ce type de test d’intrusion vise à collecter les vulnérabilités dans une application mobile ou web. Les failles les plus présentes sont telles que les injections,les ruptures d’authentification,l’exposition des données

sensibles.

Test de pénétration réseau sans fil

Les réseaux sans fil disposent d'une grande flexibilité.Cependant ils présentent des vulnérabilités qui pourraient permettre à une personne malveillante de compromettre l'infrastructure d'une entreprise.Les tests d'intrusion des réseaux sans fil consistent prin- cipalement à vérifier les faiblesses de la cryptographie mise en place,identifier les identités des utilisateurs utilisant le réseau pour trouver une potentielle utilisation non autori- sée,identifier les possibilités d'intrusion du réseau en utilisant le sans-fil.

Ingénierie sociale

L'information sociale est une type d'attaque mettant l'accent sur la naiveté des utili- sateurs d'un système.Ainsi il est question de les manipuler pour obtenir des informations confidentielles ou avoir un accés dans le système.

Test de pénétration physique

Le test de pénétration physique est une technique utilisée pour tester la sécurité phy- sique d'une entreprise,d'un réseau ou d'un système d'information. Cette méthode consiste à identifier les vulnérabilités de sécurité d'un système par rapport à sa capacité de rési- lience d'être physiquement pénétrée .Les objectifs convenus avec le client peuvent com- prendre l'accès physique à des machines, des documents confidentiels, des salles sécurisées ou même le réseau directement. Le Pentest physique peut également inclure des tests d'ingénierie sociale, où des personnes tentent de persuader ou de tromper des employés pour obtenir un accès non autorisé à une entité physique de l'entreprise.

Les différentes approches de test d'intrusion

Selon le besoin d'une organisation et la complexité des missions, les tests d'intrusion peuvent être classifiés en trois grandes catégories : tests de pénétration en whitebox ,en blackbox et en grey box.

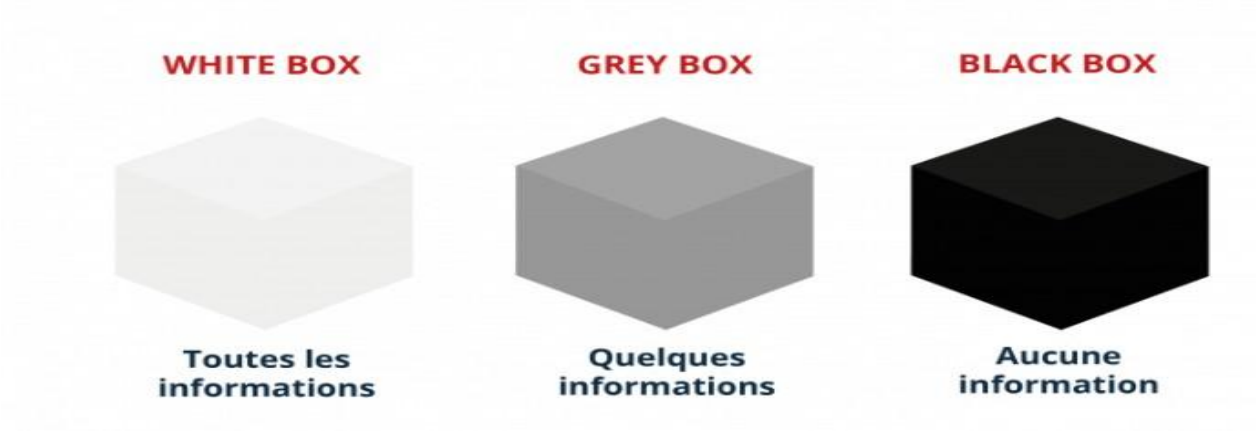

Figure 11:Différentes approches de test d'intrusion et leur spécificité.

Whitebox

Lors d'un test d'intrusion whitebox ou boite blanche, l'équipe chargée d'éffectuer le test dispose toutes les informations nécessaires et détaillées sur l'infrastruture de l'organisation. Dans une mission boite blanche les testeurs prennent connaissance des informations telles que les architectures systèmes ,les codes sources,les configurations des serveurs ainsi que les identifiants de connexion et bien plus encore.Ce type de test est souvent effec- tuée par une équipe interne de l'organisation ou parfois par des tierces spécialisées de la sécurité informatique[16].

Blackbox

En ce qui concerne le test d'intrusion blackbox ou boite noire l'équipe ne dispose aucune information au préalable sur le réseau ou le système d'information à exploiter.Cette méthologie de test reste très pertinente pour simuler une vraie cyberattaque comme un hacker malveillant[16].

Greybox

Un test d'intrusion greybox ou boite grise consiste quant à lui un combinaison des deux permiers.En effet l'organisation ne fournit que certaines informations à l'équipe sur le système à tester. Par exemple l'equipe peut avoir des informations sur l'architecture système mais pas aux codes sources.Ce type de test est utilisé lorsqu'une connaissance de certaines informations spécifiques est nécessaire pour faire des tests efficaces[16].

Benchmark des principaux frameworks et métho- dologies de Pentesting

Penetration Testing Execution Standard

La norme PTES des tests de pénétration comprend sept sections principales qui couvrent tous les aspects d'un test de pénétration, depuis l'engagement jusqu'au rapport final.

Les différentes étapes du standard PTES

Les 7 phases de la méthodologie PTES sont réparties comme suit :

Pre-engagement interactions :
Cette phase de pré-engagement connu aussi sous le nom planification permet de s'assurer que toutes les parties prenantes sont sur la même longueur d'onde. Au cours de cette phase le pentester doit coopérer avec l'organisation pour mettre le point sur la portée de la mission.Autrement dit les informations telles que la localisation de la mission,les techniques et tactiques autorisées ainsi que les outils,les systemes et sous-systèmes autorisés à tester,l'estimation de l'effort ,les restrictions et les règles de rapport

Information Gathering :
Cette partie représente une phase préparatoire où l'equipe de Pentest effectue des recherches passives (sans interactions avec le système à tester) à travers les sources ouvertes pour collecter le maxmimum d'informations sur la cible. Cette phase peut inclure :
la collecte d'informations publiques telles que les employés de l'organisation,ses adresses IP et ses noms domaines et bien plus encore.
la reconnaissance de l'infrastruture réseau : Cette reconnaissance peut être réalisée dans le but de trouver les ports ouverts par exemple,les machines connectées etc...
l'analyse des services : collecte des informations sur les versions des services en cours d'execution.
Threat Modeling :
Le Threat Modeling consiste à identifier les menaces potentielles auxquelles l'organisation testée est confrontée. Les testeurs travaillent en étroite collabo- ration avec les responsables de l'organisation pour comprendre les activités de l'entreprise, les informations critiques et les actifs importants. Ils évaluent

ensuite les différentes mé- thodes que les attaquants pourraient utiliser pour pénétrer dans le système et accéder aux informations confidentielles.

Vulnerability Analysis

Elle consiste à identifier, évaluer et classer les vulnérabilités qui ont été identifiées lors de la phase de modélisation de la menace.Les testeurs utilisent des outils de test automatisés et des techniques manuelles pour identifier les vulnérabilités dans les systèmes et les applications de l'organisation testée.

Exploitation :

Cette étape du pentest représente la phase de Poc ou Preuve de concept. Avec toutes les vulnérabilités identifiées dans la phase précédente,l'objectif de cette partie est de tenter d'exploiter toutes les vulnérabilités énumérées pour avoir un accés non autorisé au système ou aux données sensibles.

Post-Exploitation :

Cette phase consiste à explorer davantage les systèmes com- promis pour obtenir des informations sensibles et à établir une présence furtive sur les systèmes afin de prolonger l'accès.Les testeurs cherchent à obtenir un accès plus élevé aux systèmes de l'organisation testée et à recueillir des informations sensibles telles que des informations d'identification, des données financières ou des informations de propriété intellectuelle.

Reporting :

La rédaction du rapport de pentest est une phase importante et cruciale dans le processus de test de pénétration. Le rapport doit informer l'organisation toutes les phases de pentest ,les vulnérabilités détectées et la modélisation des menaces ainsi que les recommandations.Cette phase permet à l'entreprise d'avoir toutes les informations nécessaires pour améliorer sa posture de sécurité.

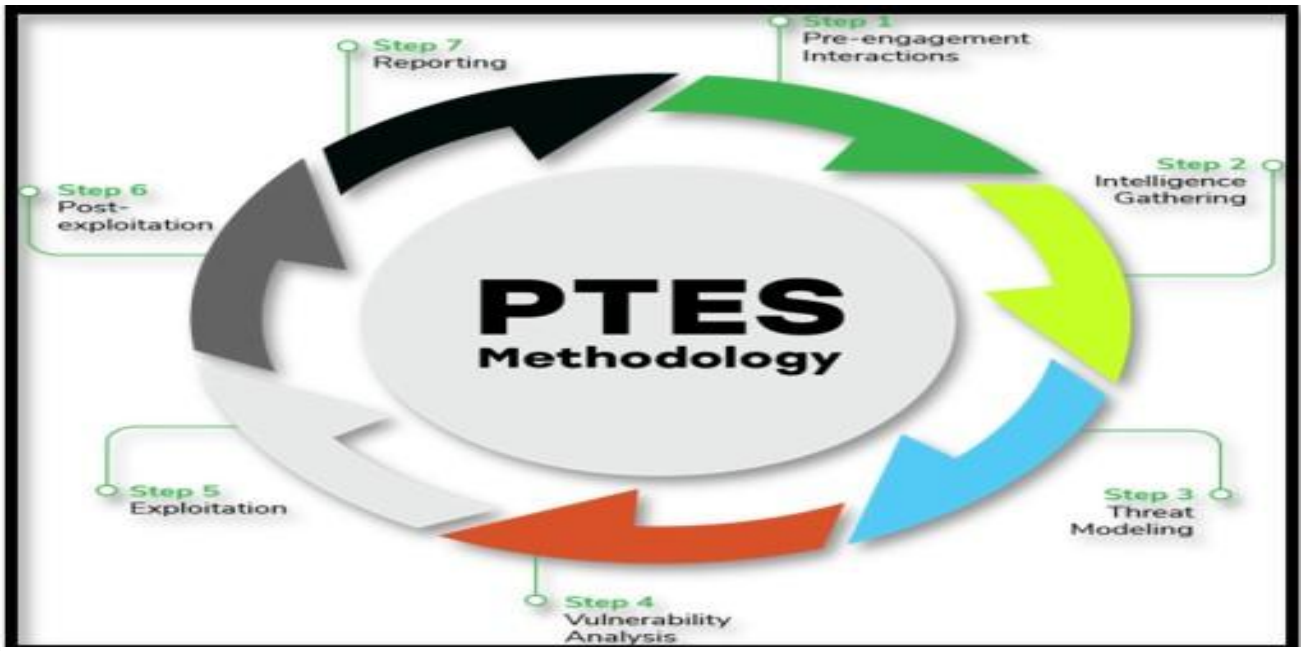

Figure 12:Les 7 phases de la méthodologie PTES

Cyber Kill Chain Framework

Le Cyber Kill Chain Framework est un modèle de référence utilisé pour décrire les différentes étapes d'une attaque informatique. Le modèle a été développé par Lockheed Martin et est dérivé de modèles d'attaques militaires pour aider les organisations à com- prendre les étapes qu'un attaquant peut suivre pour mener une attaque et comment prévenir, détecter et répondre à ces attaques.

Structure du cyber kill chain framework

Le modèle cyber kill chain est subdivisé en 7 phases allant de la reconnaissance jus- qu'à l'action sur l'objectif.Si toutes les cyberattaques n'utilisent pas les sept étapes du modèle de Cyber Kill Chain, la grande majorité des attaques en utilisent la plupart. La connaissance et la compréhension des 7 étapes de la "Cyber Kill Chain" permettent aux organisations de retracer les mouvements d'un attaquant et de prendre les mesures de sécurité nécessaires pour empêcher une telle attaque de se produire.Nous distinguons les phases suivantes [20] :

Reconnaissance :

La reconnaissance est l'une des étapes clés de la Cyber Kill chain. Les attaquants effectuent une reconnaissance en recueillant des informations sur leur cible, telles que les adresses IP,les noms de domaine, les adresses email, les noms d'utilisateurs et les informations sur les employés, les partenaires ou les fournisseurs de la cible.Ils peuvent également collecter des informations sur les systèmes d'exploitation,les applications,les ports ouverts et les protocoles de communication utilisés par la cible.

Weaponization :

L'objectif de la weaponization est de créer un vecteur d'attaque tel qu'un logiciel malveillant afin qu'il puisse être déployé avec succès sur la cible. Les atta- quants peuvent utiliser des outils sophistiqués de création de logiciels malveillants pour produire des programmes qui sont difficiles à détecter et à supprimer.

Delivery :

Dans cette phase,en général il est question pour l'attaquant de transmettre le logiciel malveillant préparé lors de la phase de weaponization à la cible visée.Les atta- quants peuvent utiliser diverses méthodes pour livrer le logiciel malveillant à la cible. Par exemple, ils peuvent utiliser des pièces jointes malveillantes dans des courriels, des sites Web malveillants.Une fois que le logiciel malveillant a été livré avec succès à la cible, il peut être activé pour exécuter son code malveillant et déclencher les actions malveillantes prévues par l'attaquant.

Exploitation :

Après avoir livré le code malveillant lors de la phase de delivery. Elle consiste à exploiter des vulnérabilités dans le système cible. Ils peuvent utiliser une va- riété de techniques pour exploiter des vulnérabilités dans le système cible. Par exemple, ils peuvent utiliser des exploits d'un logiciel malveillant pour exploiter une faille de sécurité connue.

Installation :

Après la phase d'exploitation,la prochaine étape pour l'attaquant pour- rait être d'installer une porte dérobée. Cela lui permettrait d'établir un accès permanent et non autorisé au système cible, sans avoir à se soucier d'être détecté en utilisant d'autres vecteurs d'attaque. Une porte dérobée est un logiciel malveillant qui permet à l'attaquant d'accéder au système cible à distance, en contournant les mesures de sécurité mises en place par l'organisation. L'attaquant peut alors utiliser la porte dérobée pour exécuter des commandes malveillantes, voler des informations sensibles ou compromettre davantage le système cible.

Command and Control :

L'objectif de la phase Command and Control (C2) dans le cadre de la Cyber Kill Chain est de permettre aux cybercriminels de prendre le contrôle du système cible et de communiquer avec le logiciel malveillant ou les outils qu'ils ont installé pour mener à bien leur attaque. Pendant cette phase, les attaquants établissent un canal de communication entre leur infrastructure de commande et de contrôle (C&C) et le logiciel malveillant installé sur le système cible.

Actions on objectifs :

Dans Cette dernière étapde de la Cyber Kill Chain,les cyber- criminels exécutent leur objectif final. Cette étape peut inclure des activités telles que le vol de données sensibles,la perturbation des opérations de l'organisation cible, le chantage ou l'extorsion de l'organisation, ou tout autre objectif malveillant que les cybercriminels souhaitent atteindre.

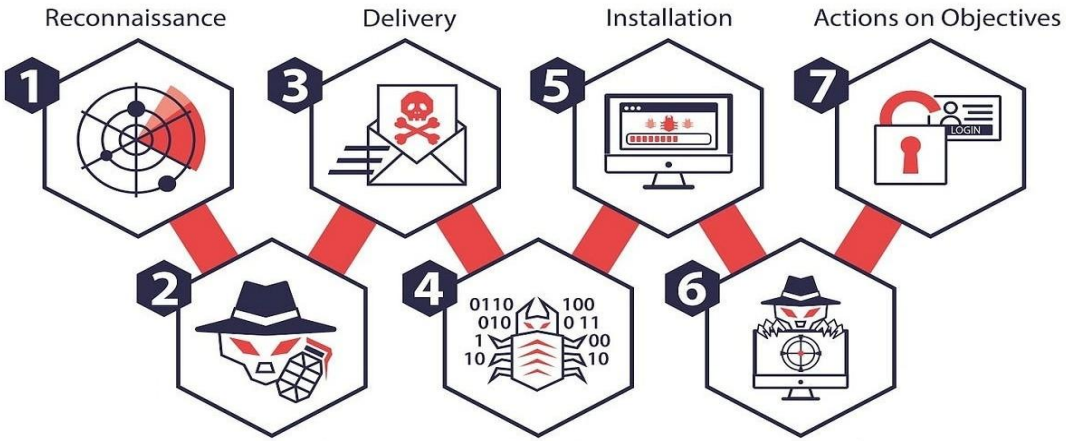

Figure 13:Les étapes de Cyber Kill Chain

Benchmark Tools

Ouitil	Type	Vitesse	Précision	Facilité d'intégretion	Mémoire utilisée	Pourquoi le choisir ?
subfinder	Subdomain discovery	Rapide	Moyenne	Très facile	Faible	Idéal pour découvrir rapidement des sous-domaines via une approche passive et active.
Dig	DNS lookup	Très rapide	Précision élevée	Très facile	Faible	Pour effectuer des requêtes DNS rapides et obtenir des informations précises sur les enregistrements DNS d' un domaine.
WPSCan	Vulnerability scanner	Modéré	Haute précision	Moyenne	Modérée	Outil dédié pour la sécurité des sites WordPress.
ffuf	Directory brute-forcing	Très rapide	Moyenne	Très facile	Faible	Pour effectuer des attaques de brute-force sur des répertoires et fichiers non répertoriés
assetfinder	Subdomain discovery	Rapide	Moyenne	Facile à intégrer dans des scripts	Faible	Outil rapide pour découvrir les sous-domaines d' un domaine cible.
whatweb	Web technology fingerprinting	Modéré	Moyenne	Moyenne	Faible	Permet de collecter des informations sur les technologies utilisées par un site web.
Burp Suite	Vulnerability scanner /Proxy	Modéré	Très élevée	Moyenne	Modérée à élevée	Excellent pour l'analyse manuelle des vulnérabilités et le test de pénétration approfondi.
sslscan	SSL/TLS scanner	Rapide	Précision élevée	Facile	Faible	Analyse des certificats SSL/TLS pour vérifier la sécurité des connexions.

Figure 14:Tableaux de Benchmark

Chapitre III

L'automatisation de Penteste sur la cible WebGoat

Figure 15:OWASP - WebGoat

Introduction

WebGoat est une application web éducative développée par OWASP pour permettre aux professionnels de la sécurité d'apprendre et de pratiquer l'identification et l'exploitation de vulnérabilités courantes dans les applications web. L'objectif de ce pentest était de simuler une attaque réaliste sur l'application afin d'identifier les vulnérabilités potentielles et de recommander des mesures correctives pour sécuriser davantage l'application.

Objectifs du Pentest

Le but principal de ce test d'intrusion était d'identifier, exploiter et documenter les failles de sécurité présentes dans l'application WebGoat. Les objectifs spécifiques incluent :

- **Identification des Vulnérabilités** : Découvrir les failles de sécurité dans l'application WebGoat.
- **Évaluation du Niveau de Risque** : Analyser l'impact potentiel de ces vulnérabilités sur l'application et ses utilisateurs.
- **Recommandations** : Fournir des recommandations pour corriger les failles découvertes et améliorer la sécurité globale de l'application.

Méthodologie

Pour ce test d'intrusion, une approche manuelle et automatisée a été utilisée, combinant différents outils de pentesting et des techniques d'exploitation. La méthodologie suivie inclut :

- **Reconnaissance** : Collecte d'informations sur l'application et son infrastructure.
- **Scan de Vulnérabilités** : Utilisation d'outils comme OWASP ZAP et Burp Suite pour détecter les vulnérabilités.
- **Exploitation** : Tentative d'exploitation des vulnérabilités identifiées, comme les injections SQL, les failles XSS, et les vulnérabilités CSRF.
- **Analyse Post-Exploitation** : Évaluation des implications de chaque vulnérabilité exploitée.
- **Rapport et Recommandations** : Compilation des résultats et des recommandations de sécurité.

Limites et Contexte du Test

Il est important de noter que WebGoat est une application volontairement vulnérable, conçue à des fins éducatives. Par conséquent, les failles découvertes ne reflètent pas nécessairement des problèmes réels que l'on trouverait dans des applications de production. Ce test a été effectué dans un environnement contrôlé avec l'objectif de renforcer les compétences en matière de sécurité applicative.

Synthèse des Résultats

Les sections suivantes du rapport détailleront les vulnérabilités découvertes, les méthodes utilisées pour les identifier et les exploiter, ainsi que les recommandations pour les corriger. Chaque vulnérabilité est classée par niveau de risque, allant de faible à critique, avec une analyse de l'impact potentiel sur l'application et ses utilisateurs.

Pré-requis

Avant de procéder à l'installation de WebGoat, les éléments suivants doivent être en place :

- **Système d'exploitation :** [Insérez votre système d'exploitation, par exemple Ubuntu 20.04]
- **Docker :** Docker doit être installé et configuré sur le système.

Étapes d'Installation

Vérification de l'installation de Docker

La première étape consiste à vérifier que Docker est installé et fonctionne correctement. Cette vérification a été réalisée en exécutant la commande suivante :

```bash
docker --version
```

Résultat attendu : Affichage de la version de Docker installée sur le système.

Téléchargement et exécution de WebGoat

Pour déployer WebGoat via Docker, la commande suivante a été exécutée :

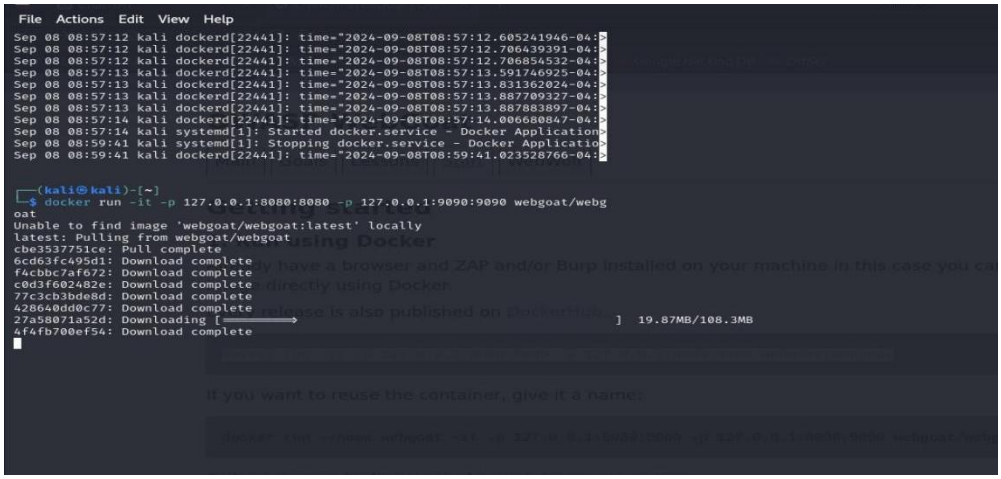

Figure 16:déployer WebGoat via Docker

- **-d** : Cette option exécute le conteneur en arrière-plan.
- **-p 8080:8080** : Cette option mappe le port 8080 du conteneur au port 8080 de l'hôte, permettant l'accès à WebGoat via http://localhost:8080/WebGoat.

Vérification du fonctionnement de WebGoat

Une fois le conteneur en cours d'exécution, WebGoat a été accessible via un navigateur web à l'adresse suivante :

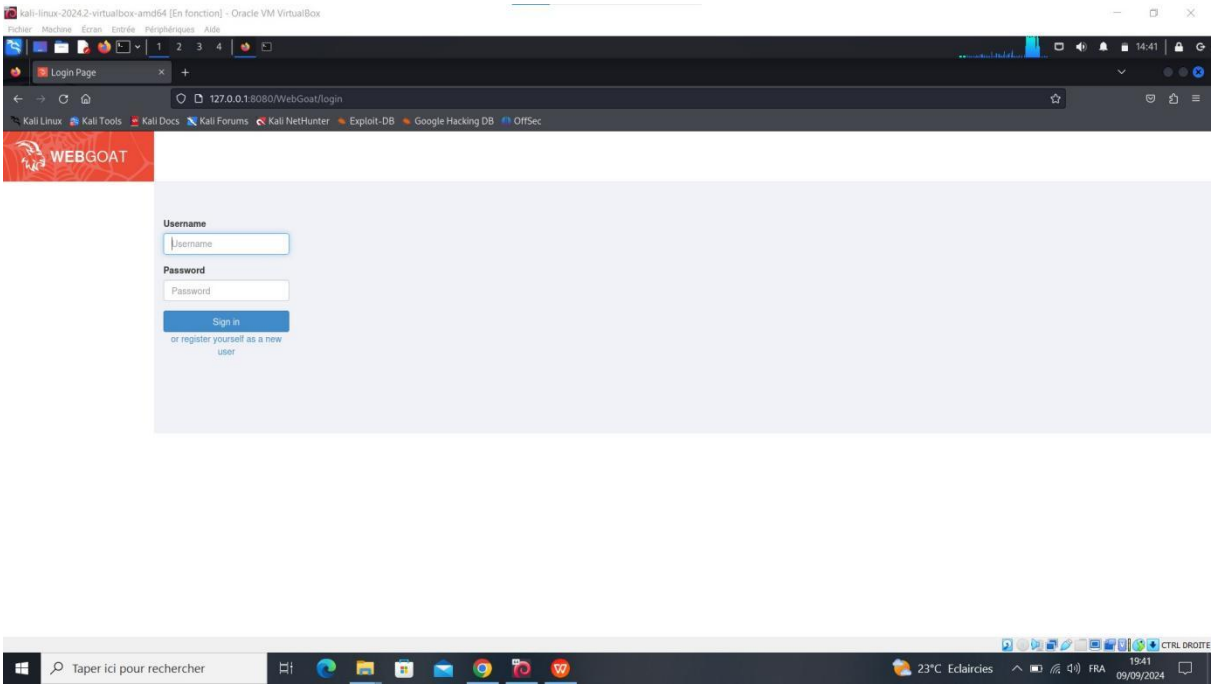

Figure 17:Vérification de L'accessible via Webgoat

2. S'inscrire en tant que Nouvel Utilisateur

Remplissez le formulaire d'inscription avec les informations demandées :

- **Nom d'utilisateur :** Choisissez un nom d'utilisateur unique.
- **Mot de passe :** Créez un mot de passe sécurisé.
- **Confirmer le mot de passe :** Entrez à nouveau le mot de passe pour confirmer.
- **Email (si demandé) :** Entrez une adresse email valide.

Une fois le formulaire rempli, cliquez sur le bouton "S'inscrire" ou "Register".

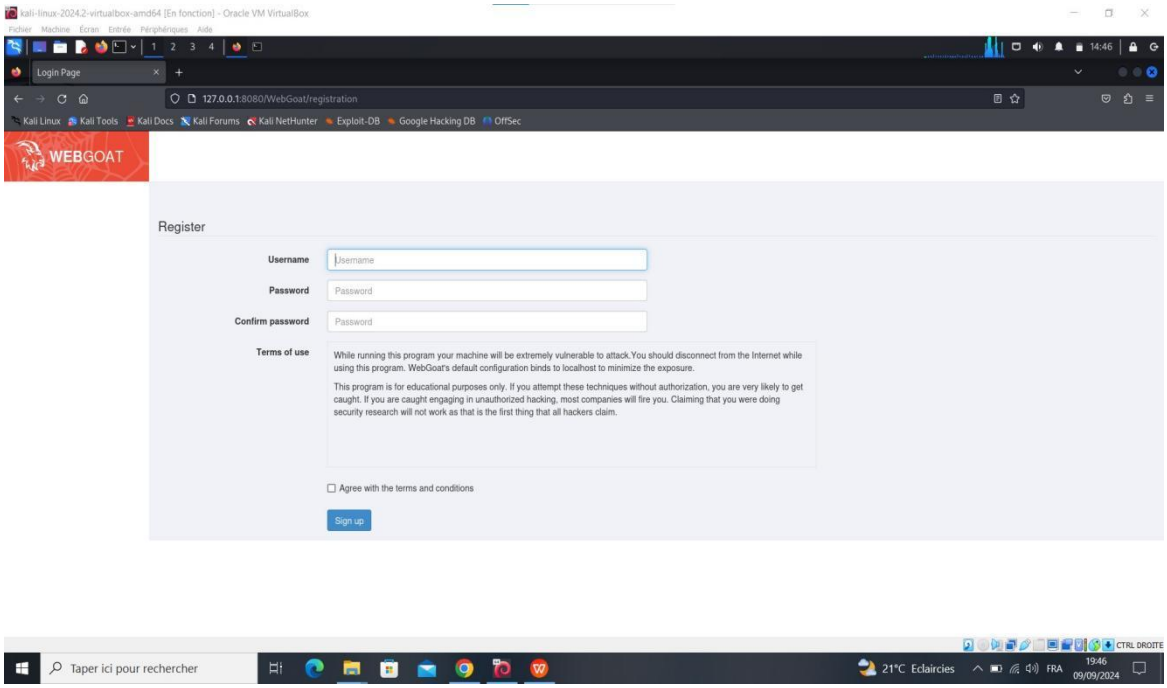

Figure 18:S'inscrire dans webgoat

Rapport de Pentest : Challenge "WebGoat - Without Password"

Date du test : 17 septembre 2024

Durée du test : 1 heur

Cible : WebGoat (localhost:8080) - Challenge "Without Password"

Outils utilisés : Burp Suite, navigateur web, interception des requêtes HTTP, WebGoat

Objectif : Exploiter une vulnérabilité d'authentification permettant d'accéder à une ressource sans fournir de mot de passe valide.

Méthodologie

Reconnaissance :

Outils d’évaluation

reconn.py est un outil que nous avons développé durant notre stage dans le but d’automatiser des tâches dans notre méthodologie de pentest de Web Application.

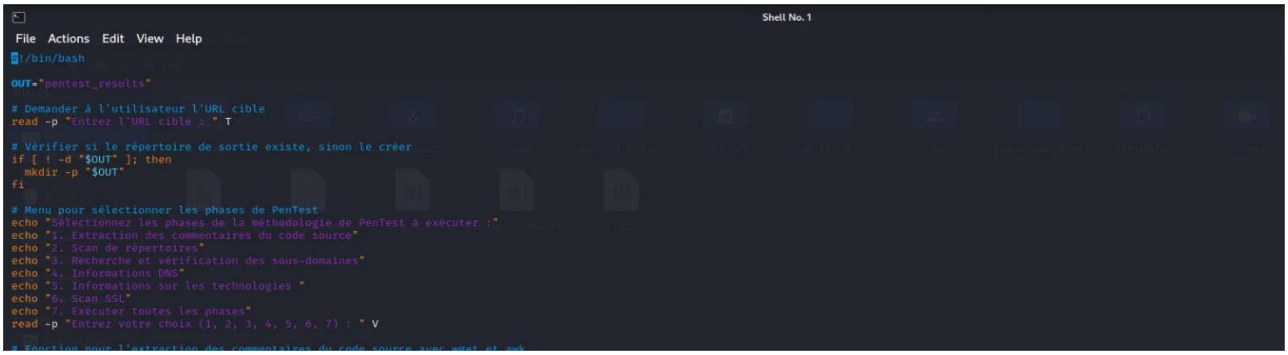

Figure 19:Outil de Automatisée de PenTest sur les Applications Web

OPTION 1 : Applications Web Enumeration

nous permet d'énumérer Challenge "WebGoat - Without Password"dans une mission de PenTest.pour lister le maximum d'informations possibles et Faciliter les prochaines étapes.

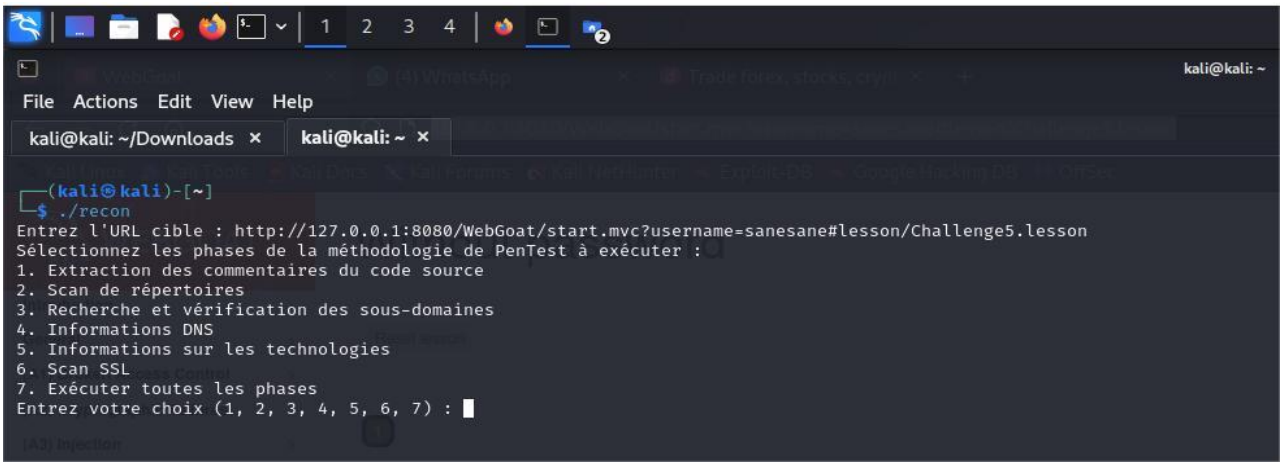

Figure 20:Enumeration Challenge "Without Password"

Accès à l'application WebGoat :

WebGoat est une application d'entraînement aux tests de sécurité, disponible localement sur http://127.0.0.1:8080.

Lors du lancement, l'application propose une interface avec différents modules de tests de sécurité, chaque module représentant un type de vulnérabilité ou un cas d'usage particulier.

Exploration de la structure de l'application.

En explorant les différents modules de WebGoat, on peut observer que certaines pages nécessitent une authentification (connexion avec un nom d'utilisateur et un mot de passe).

Ces pages protégées peuvent inclure des leçons spécifiques ou des challenges, comme le challenge "Without Password", où le but est de contourner cette protection.

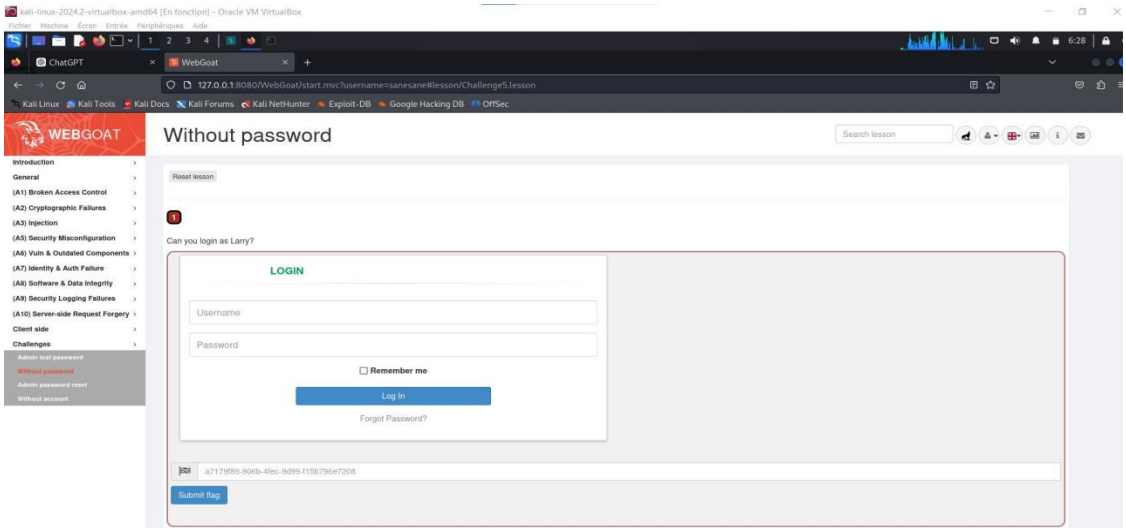

Figure 21:Login à Webgoat et voir le challenge Without Password

Inspection des requêtes HTTP :

En naviguant sur l'application, des outils comme Burp Suite ou OWASP ZAP sont utilisés pour intercepter et analyser les requêtes HTTP.

Chaque tentative d'accès à une page protégée déclenche une requête POST ou GET contenant des informations d'identification (nom d'utilisateur, mot de passe).

Les formulaires de connexion, comme celui utilisé dans le challenge "Without Password", envoient les données à des endpoints spécifiques pour vérifier les informations d'identification.

Analyse des vulnérabilités :

1 **Burp Suite** est lancé en mode proxy pour intercepter les requêtes entre le navigateur et l'application WebGoat (ou toute application cible).

* Le navigateur est configuré pour passer par le proxy de Burp Suite (généralement 127.0.0.1:8080).

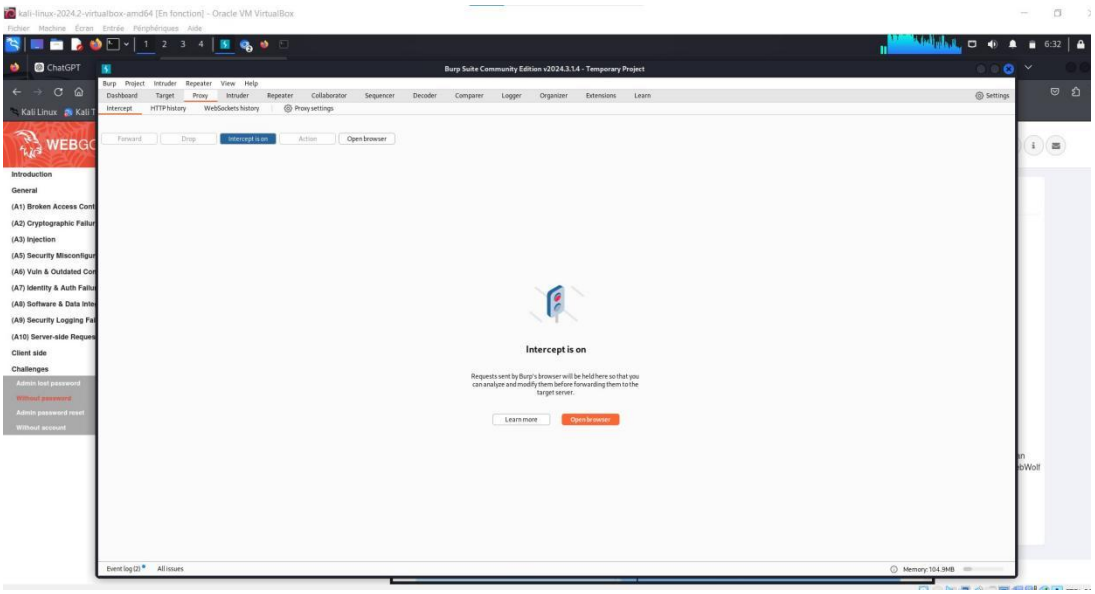

Figure 22:lancé proxy de burp suite

2. Interception de la requête de connexion :

* Une fois Burp Suite en place, navigue sur la page de connexion de WebGoat, où les utilisateurs doivent entrer leur nom d'utilisateur et mot de passe (comme dans le challenge *Without Password*).

* Lorsque l'utilisateur tente de se connecter, une requête HTTP POST est envoyée à l'application.

* Burp Suite intercepte cette requête avant qu'elle n'atteigne le serveur, permettant ainsi de l'analyser en détail.

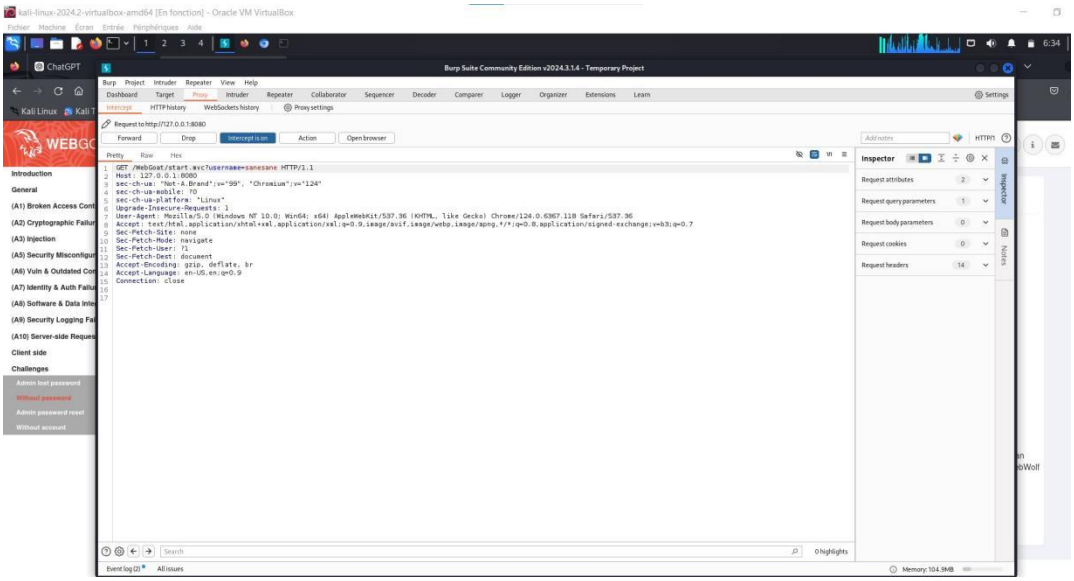

Figure 23:lancé proxy de burp suite

Interception de la requête

Analyse des champs sensibles :

- En examinant la requête interceptée, plusieurs champs sensibles peuvent être identifiés :

  username_login : Le nom d'utilisateur entré par l'utilisateur (ici, "Larry").

  password_login : Le mot de passe associé (ici, "password").

  remember : Un champ indiquant si l'option "Se souvenir de moi" est activée.

2. Test initial avec Burp Suite :

- En interceptant la requête HTTP POST contenant les informations de connexion, voici un exemple de la structure de la requête interceptée dans **Burp Suite** :

```
POST /WebGoat/challenge/5 HTTP/1.1

Host: 127.0.0.1:8080

Content-Type: application/x-www-form-urlencoded

username_login=Larry&password_login=password&remember=on
```

Injection SQL dans le champ de mot de passe :

- Le test d'injection SQL consiste à modifier le champ password_login pour insérer du code SQL malveillant.
- Une technique courante pour contourner l'authentification consiste à utiliser l'injection suivante : ’

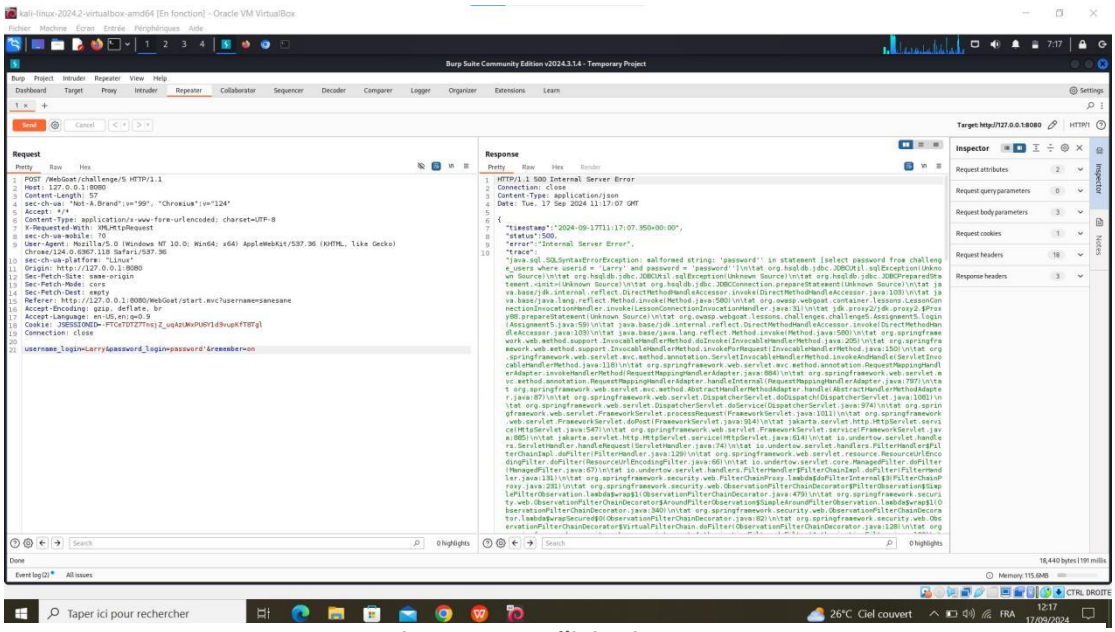

Figure 24:Test d'injection SQL

Comme vous pouvez le constater, le mot de passe a été intégré avec succès.

Exploitation :

Vulnérabilité exploitée : Injection SQL dans le champ `password_login`

Détails de l'exploitation :

Lors du test de sécurité sur l'application WebGoat- Without Password, l'objectif était de contourner le mécanisme d'authentification en exploitant une vulnérabilité d'injection SQL dans le champ de mot de passe lors de l'envoi d'une requête POST

- **Injection SQL utilisée :**
  - Le champ `password_login` a été modifié avec une injection SQL de type `' OR '1'='1`, qui force une condition toujours vraie au niveau de la requête SQL.
- **Requête POST interceptée et modifiée :**
  - Voici la requête POST interceptée dans **Burp Suite**, puis modifiée pour inclure l'injection SQL :

Comportement de la requête côté serveur :

- Le serveur traite la requête SQL de la manière suivante

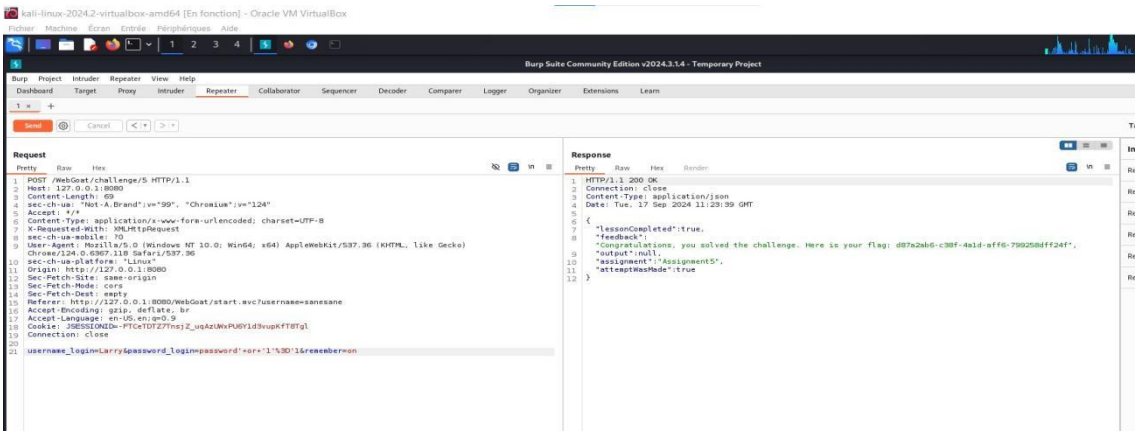

Figure 25:exploitée Injection SQL

```
SELECT * FROM users WHERE username='Larry' AND password='' OR '1'='1'
```

L'injection OR '1'='1' crée une condition toujours vraie, ce qui signifie que la vérification du mot de passe est contournée, et l'utilisateur peut accéder à l'application sans fournir un mot de passe valide.

Résultat de l'attaque :

- L'exploitation réussie a permis d'accéder à la ressource protégée sans authentification.

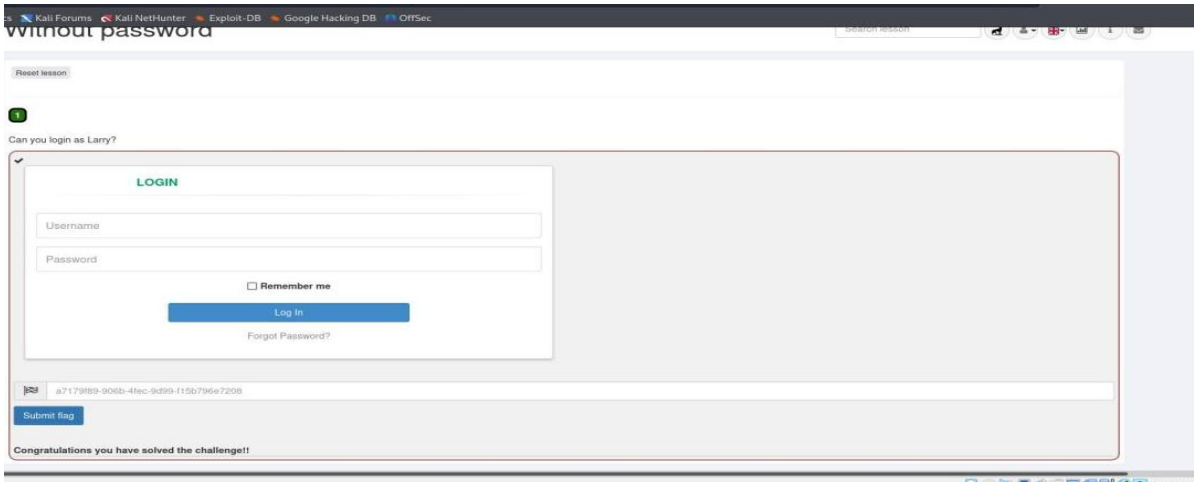

Figure 26:L'exploitation réussie

Inspection des requêtes HTTP envoyées lors des tentatives d'accès aux pages protégées.

Impact :

Niveau de Danger : Élevé

Raisons :

Impact Potentiel : La vulnérabilité d'injection SQL dans le champ password_login permet de contourner le mécanisme d'authentification en utilisant une condition toujours vraie ('1'='1'). Cela peut permettre un accès non autorisé à des ressources protégées, compromettant ainsi la sécurité de l'application.

Exploitation Facile : L'injection SQL est relativement facile à exploiter avec des connaissances de base en SQL. Une fois exploitée, elle peut permettre à un attaquant d'accéder, de modifier ou de supprimer des données dans la base de données, ce qui a des conséquences graves pour la sécurité.

Score CVSS : Le score CVSS typique pour une vulnérabilité d'injection SQL est généralement élevé (autour de 7.0 à 10.0), ce qui correspond à un niveau de danger élevé.

Résumé du Niveau de Danger :

Niveau de Danger : **Élevé**

Impact : Accès non autorisé aux ressources protégées et potentiel de compromission de la sécurité des données.

Recommandation:

Pour corriger la vulnérabilité d'injection SQL que tu as identifiée dans le challenge **WebGoat - Without Password**, voici des recommandations détaillées :

Recommandations pour Corriger l'Injection SQL

Utiliser des Requêtes Préparées (Prepared Statements) :

Description : Les requêtes préparées séparent les instructions SQL des données utilisateur. Cela empêche les données utilisateur de manipuler la structure de la requête SQL, réduisant ainsi les risques d'injection SQL.

Exemple en Java :

```
String query = "SELECT * FROM users WHERE username = ?
AND password = ?";

PreparedStatement pstmt =
connection.prepareStatement(query);

pstmt.setString(1, username);

pstmt.setString(2, password);

ResultSet rs = pstmt.executeQuery();
```

Utiliser des ORM (Object-Relational Mapping) :

- **Description :** Les ORM comme Hibernate (Java), Entity Framework (.NET), ou SQLAlchemy (Python) gèrent les interactions avec la base de données de manière sécurisée, en utilisant des requêtes paramétrées par défaut.
- **Avantage :** Réduit le besoin d'écrire des requêtes SQL directement, minimisant ainsi les risques d'injection SQL.

· **Validation et Échappement :** Valider les entrées et échapper les caractères spéciaux.

- **Contrôle d'Accès :** Assurer que les ressources sont protégées correctement.
- **Validation Côté Serveur :** Toujours vérifier les données côté serveur.
- **Pare-feu Applicatif :** Utiliser pour filtrer les requêtes malveillantes.
- **Tests de Sécurité :** Effectuer régulièrement pour détecter les vulnérabilités.

Conclusion

Le challenge "Without Password" de WebGoat a mis en évidence une vulnérabilité critique d'Injection SQL, permettant de contourner le mécanisme d'authentification et d'accéder à des ressources protégées sans autorisation. Cette faille expose l'application à des risques importants, tels que l'accès non autorisé à des données sensibles et la possibilité d'exécuter des actions malveillantes. Pour remédier à cette vulnérabilité, il est impératif d'adopter des pratiques de sécurité robustes, telles que l'utilisation de requêtes préparées, la validation rigoureuse des entrées, et la mise en place de contrôles d'accès appropriés. En intégrant ces recommandations et en réalisant des tests de sécurité réguliers, vous renforcerez considérablement la sécurité de l'application et réduirez les risques de compromission. La sécurité continue d'être une priorité essentielle pour protéger les données et assurer la fiabilité des systèmes d'information.